

The Practitioner's Blueprint for Secure AI

By John M. Willis, Quantum Powered Security, Inc.



August 2025

Copyright and License

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc.

This manuscript is licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0). You are free to share and adapt this work for any purpose, including commercial use, provided appropriate attribution is given.

License: <https://creativecommons.org/licenses/by/4.0/>

Patent Notice

The concepts, architectures, and reference designs presented in this work are intended to encourage adoption, adaptation, and further innovation. Readers are encouraged to tailor PBSAI to their own environments, products, and services. Novel implementations, extensions, and improvements developed by others may be eligible for intellectual property protection under applicable patent laws.

The authors likewise reserve all rights to pursue patent protection for their own inventions, implementations, improvements, and future developments related to PBSAI. Certain aspects of this work are the subject of pending patent applications. Except as expressly stated by applicable law, no patent rights are granted or implied by this publication or its CC BY 4.0 license.

Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem

Domain C – ICAM

Table of Contents

Domain C - Identity, Credential, and Access Management (ICAM)	4
C1. Identity Provisioning Agent.....	4
Agent Blueprint [Informative].....	4
Technical Implementation Details (C1) [Informative]	15
MCP-Native Protocol Specification (C1) [Normative]	17
C2. Auth Policy Agent	18
Agent Blueprint [Informative].....	18
Technical Implementation Details (C2) [Informative]	28
MCP-Native Protocol Specification (C2) [Normative]	30
C3. Access Control Agent	31
Agent Blueprint [Informative].....	31
Technical Implementation Details (C3) [Informative]	43
MCP-Native Protocol Specification (C3) [Normative]	45
C4. Privileged Session Monitor Agent.....	45
Agent Blueprint [Informative].....	45
Technical Implementation Details (C4) [Informative]	56
MCP-Native Protocol Specification (C4) [Normative]	59
C5. Identity Federation Agent	59
Agent Blueprint [Informative].....	59
Technical Implementation Details (C5) [Informative]	71
MCP-Native Protocol Specification (C5) [Normative]	73
C6. Access Audit Agent.....	74
Agent Blueprint [Informative].....	74
Technical Implementation Details (C6) [Informative]	84
MCP-Native Protocol Specification (C6) [Normative]	87
C7. Crypto Key Manager Agent	87
Agent Blueprint [Informative].....	87
Technical Implementation Details (C7) [Informative]	100
MCP-Native Protocol Specification (C7) [Normative]	102

Domain C - Identity, Credential, and Access Management (ICAM)

C1. Identity Provisioning Agent

Agent Blueprint [Informative]

Purpose: Automate JML (joiner/mover/leaver) provisioning across directories and apps with just-in-time SLAs.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **HRIS Webhooks/REST (Workday/SuccessFactors)** — hire/transfer/terminate events (employee_id, action, effective_date, department, manager_id, location, employment_type, title, email).
- **Role Model Catalog (Git/REST)** — role_id → entitlements mapping; SoD conflicts; approver chains.

Model training / knowledge (what the LLM relies on):

- Style/policy prompt-pack for ICAM norms (least privilege, SoD, JIT/JEA), directory/app provisioning playbooks, approval policies.
- RAG sources: HRIS field dictionary, role catalog repository history, SoD policy index, SCIM profiles; do **not** train on regulated PII—use evidence_refs to fetch on demand.
- Guardrails: SCIM scope allowlist (users/groups only); deny admin role grants; tool scopes constrained per target (Okta/Azure AD/GitHub/Jira/GCP).

Decisions it makes (deterministic + model-assisted):

- **Role resolution:** derive baseline role(s) from HRIS attributes (department, job_title, location, employment_type).
- **Entitlement expansion:** map roles → entitlements; collapse duplicates; remove ineligible items (location or employment_type constraints).
- **SoD screening:** detect conflicts (e.g., FIN_AP_PROD_ACCESS) and **block or route to HITL** per severity.
- **Approval routing:** if elevated/exceptional entitlements requested, route to approvers; enforce timebox_15m SLA for baseline JML path.

- **Action selection:** create/update/deprovision via SCIM; schedule revocation windows for movers/leavers.
- **Classification:** mark outputs C2 when PII is present.

Routing / where outputs go:

- **SCIM 2.0** mutations to target directories/apps (create/update/deprovision; group membership changes).
- **Kafka AccessChange** events to notify downstream systems (SIEM, PAM, data platforms).
- **Tickets/alerts:** open workflow items on SoD conflicts, SLA risks, or API errors; attach evidence_refs.

Automation scope vs. manual/HITL:

- **Fully automated:** baseline joiner create; baseline mover delta (group adds/removes) without conflicts; leaver disable + staged delete; profile sync.
- **HITL required:** any SoD conflict flagged; privileged roles beyond baseline; backdated HRIS effective_date; inconsistent identity graphs (duplicate emails).
- **Manual outside agent:** exception role design; SoD policy authoring; remediation of source-of-truth data errors.

Security Domain: ICAM (Identity, Credential, and Access Management)

Inputs (native protocols consumed) [Informative]

1. **HRIS Webhooks/REST (Workday/SuccessFactors)** — JML events.
2. **Role Model Catalog (Git/REST)** — role definitions and SoD constraints.

Example: Consumed Protocol — HRIS Webhook/REST (Joiner/Move/Leaver)

[Informative]

Native payload (Hire)

```
{
  "event_id": "hris-evt-78421",
  "action": "hire",
  "effective_date": "2025-08-18",
  "employee": {
    "employee_id": "E102993",
```

```

    "given_name": "April",
    "family_name": "Ng",
    "email": "april.ng@example.com",
    "manager_employee_id": "E100014",
    "department": "Payments Engineering",
    "location": "NYC",
    "employment_type": "FTE",
    "job_title": "Software Engineer"
  }
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-c1-jml-1111-2222-3333-4444",
    "thread_id": "uuid-hris-hris-evt-78421",
    "task_id": "uuid-a1b2-c3d4-e5f6-7788",
    "role": "IdentityProvisioningAgent",
    "intent": "provision",
    "constraints": ["timebox_15m"],
    "policy_refs": ["AC-2", "IA-2"],
    "decision_basis": {
      "evidence_refs": ["uri://hris/events/hris-evt-78421"],
      "confidence": 0.99
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/icam/identity-provisioning-agent",

```

```

    "signing_kid": "kid-hris-c1-01",
    "attestation_ref": "uri://slsa/attestations/icam-provision@sha256:hris01"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — Role Model Catalog (Git/REST) [Informative]
 Native payload (Role → Entitlements)

```

{
  "role_id": "ENG_SW_L1",
  "description": "Payments SWE L1 baseline",
  "entitlements": [
    {"system": "okta", "group": "eng-swe-l1"},
    {"system": "github", "team": "payments-read"},
    {"system": "jira", "role": "developer"},
    {"system": "gcp", "iam_role": "roles/viewer"}
  ],
  "approvers": ["payments.eng.manager"],
  "sod_conflicts": ["FIN_AP_PROD_ACCESS"]
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-c1-role-5555-6666-7777-8888",
    "thread_id": "uuid-role-ENG_SW_L1",

```

```

"task_id": "uuid-99aa-bbcc-ddee-ff00",
"role": "IdentityProvisioningAgent",
"intent": "provision",
"constraints": ["timebox_15m"],
"policy_refs": ["AC-2", "AC-5", "PS-3"],
"decision_basis": {
  "evidence_refs": ["uri://git/icam/roles/ENG_SW_L1.json"],
  "confidence": 0.96,
  "explanation_ref": "uri://kb/icam/role-engineering-guidelines"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/icam/identity-provisioning-agent",
  "signing_kid": "kid-role-c1-02",
  "attestation_ref": "uri://slsa/attestations/icam-provision@sha256:role02"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **SCIM 2.0** user/group mutations (create/update/deprovision; membership add/remove).
- **AccessChange** events on Kafka for downstream sync and observability.

MCP context (required) [Informative]

mission_id; role="IdentityProvisioningAgent"; intent="provision";
constraints=["timebox_15m"]; provenance.attestation (SLSA/SPIFFE + KID)

MCP context (optional) [Informative]

policy_refs (e.g., AC-2, IA-2); classification (C2); decision_basis

Enforcement note [Informative]

PEPs must enforce **timebox_15m** SLA for baseline joiners and verify provenance attestation on all SCIM mutations; SoD conflicts must be blocked or HITL-approved.

NIST SP 800-160v2 linkage [Informative]

Develop/Implement/Maintain — resilient identity lifecycle with fault tolerance and bounded-time actions.

Automation feasibility [Informative]

High (deterministic mappings + mature SCIM ecosystems + event-driven JML).

Output Contracts (merged) [Informative]

OC-1: SCIMMutation (create/update/deprovision) [Informative]

- **Producer(s):** C1
- **Topic/Path:** HTTPS SCIM endpoint per target (e.g., <https://idp/scim/v2/Users>, .../Groups)
- **Schema/Format:** RFC 7643/7644 SCIM JSON; profile-specific extensions documented per target
- **Classification:** C2 (PII)
- **Delivery:** exactly-once per target_user_id per operation_type (consumer enforces idempotency)
- **Ordering:** per target_user_id
- **Idempotency-Key:** sha256(target_system, operation_type, target_user_id, version_floor_60s)
- **Ack/Nack:** HTTP 2xx = ACK; 4xx/5xx = NACK (retry/backoff; open ticket if repeated)
- **Timeouts/Retry:** ack<=15s; exp-backoff<=5x; circuit-breaker on persistent 5xx
- **Side-Effects:** update identity graph; emit AccessChange event
- **HITL Token:** required when SoD conflict unresolved or privileged role grant
- **Observability:** trace_id, mission_id, evidence_refs, decision_basis.*, classification_label, provenance.attestation

- **Retention/TTL:** 7 years (request/response hash and journal only; not full PII payload)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=SCIMMutation@1.0 | json_schema_uri=uri://schema/scim-mutation-1.0.json | sha256= | producers=C1 | consumers=Okta-01, AzureAD-01, GitHub-01, Jira-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: AccessChangeEvent (downstream notification) [Informative]

- **Producer(s):** C1
- **Topic/Path:** Kafka icam.access.change.v1
- **Schema/Format:** Avro/JSON: {event_id, employee_id, action, entitlements_delta[], effective_ts, source, reason}
- **Classification:** C1 (minimized PII)
- **Delivery:** at-least-once
- **Ordering:** per employee_id
- **Idempotency-Key:** sha256(event_id)
- **Ack/Nack:** broker ACK (ISR quorum); NACK on publish failure → retry/backoff
- **Timeouts/Retry:** publish≤2s; exp-backoff≤7x
- **Side-Effects:** downstream sync (PAM, data platforms, audit lake)
- **HITL Token:** none
- **Observability:** trace_id, mission_id, policy_refs, decision_basis.summary_ref
- **Retention/TTL:** 1 year

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When event-driven downstream integration is enabled

schema_id=AccessChangeEvent@1.0 | json_schema_uri=uri://schema/access-change-1.0.json | sha256= | producers=C1 | consumers=SIEM-01, PAM-01, DataOps-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: SoDViolation (contestability pathway) [Informative, optional]

- **Producer(s):** C1, Manager-Portal-01
- **Topic/Path:** icam.sod.violation
- **Schema/Format:** SoDViolation@1.0
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-employee_id
- **Idempotency-Key:** sha256(employee_id, violation_code, role_id)
- **Ack/Nack:** case_id assigned; retry/backoff
- **Side-Effects:** open approval workflow; block SCIMMutation until resolved
- **HITL Token:** required for override
- **Observability:** trace_id, mission_id, decision_rationale_url
- **Retention/TTL:** 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability and SoD governance workflows are enabled
schema_id=SoDViolation@1.0 | json_schema_uri=uri://schema/sod-violation-1.0.json

OC-4: SLABreachAlert (timebox enforcement) [Informative, optional]

- **Producer(s):** C1
- **Topic/Path:** icam.sla.breach
- **Schema/Format:** SLABreachAlert@1.0
- **Classification:** C1
- **Delivery/Ordering:** at-least-once
- **Idempotency-Key:** sha256(mission_id, employee_id, action)
- **Ack/Nack:** alert_id assigned; retry/backoff
- **Side-Effects:** page on-call; throttle new noncritical jobs
- **HITL Token:** none

- **Observability:** trace_id, mission_id, elapsed_ms
- **Retention/TTL:** 1 year

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When SLA monitoring is enabled for JIT provisioning

schema_id=SLABreachAlert@1.0 | json_schema_uri=uri://schema/sla-breach-1.0.json

OC-5: DeprovisionCertificate (leaver attestation) [Informative, optional]

- **Producer(s):** C1
- **Topic/Path:** icam.attest.deprovision
- **Schema/Format:** JSON: {employee_id, accounts_revoked[], timestamp, attester, evidence_refs[]}
- **Classification:** C1
- **Delivery/Ordering:** at-least-once
- **Idempotency-Key:** sha256(employee_id, timestamp_floor_1h)
- **Ack/Nack:** stored in evidence lake
- **Side-Effects:** publish to GRC evidence store
- **HITL Token:** none
- **Observability:** trace_id, mission_id, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-5) [Normative]

Requirement Level: Optional

Condition: When formal deprovision attestations are required

schema_id=DeprovisionCertificate@1.0 | json_schema_uri=uri://schema/deprovision-certificate-1.0.json

OC-6: FeedbackIngestionEvent (helpdesk/user loop) [Informative, optional]

- **Producer(s):** Helpdesk portal; C1 (aggregation)
- **Topic/Path:** icam.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0

- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-ticket-id
- **Idempotency-Key:** sha256(ticket_id)
- **Ack/Nack:** feedback_id assigned
- **Side-Effects:** learning queue for rubric/prompt updates
- **Observability:** trace_id, mission_id, artifact_id, labels={helpful|neutral|harmful}
- **Retention/TTL:** 1 year

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

State machine (concise) [Informative]

```
states = { idle, awaiting_hris_event, role_resolution, sod_check, awaiting_approval,
provisioning, verifying, contestation_workflow, sla_breach, rolled_back, closed }
transition(idle -> awaiting_hris_event) when HRIS event received
transition(awaiting_hris_event -> role_resolution) when event.valid and effective_date
<= now
transition(role_resolution -> sod_check) when roles derived
transition(sod_check -> awaiting_approval) when conflict_detected = true
transition(sod_check -> provisioning) when conflict_detected = false
transition(awaiting_approval -> provisioning) when approval_granted = true
transition(provisioning -> verifying) when SCIM responses ACK
transition(verifying -> closed) when entitlements_state == desired_state
transition(provisioning -> rolled_back) on partial_failure and rollback_possible
transition(* -> sla_breach) when elapsed_ms > 15 * 60 * 1000 and action in {hire,
terminate}
transition(* -> contestation_workflow) when AccessDispute/SoDViolation opened

timeout(provisioning, 15s) -> retry; retry <= 5 with exp backoff
idempotency_key = sha256(target_system, operation_type, target_user_id,
version_floor_60s)
```

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 SCIMMutation	Required	Always	Core JML execution
OC-2 AccessChangeEvent	Conditionally Required	Event-driven downstream integrations present	Ecosystem synchronization
OC-3 SoDViolation	Optional	Contestability/SoD workflow enabled	Governance + risk control
OC-4 SLABreachAlert	Conditionally Required	SLA monitoring enabled for JIT provisioning	Reliability/SRE action
OC-5 DeprovisionCertificate	Optional	Formal attestation required	Compliance evidence
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow enabled	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** AC-2 (Account Management), IA-2 (Identification and Authentication), PS-3 (Personnel Screening), CM-5 (Access Restrictions).
- **HITL required:** SoD conflicts; privileged access beyond baseline; backdated or future-dated HRIS events beyond policy window; cross-region data moves violating locality.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; stakeholder_disagreement_score >= 0.5; duplicate identity detected.
- **Manual outside agent:** exception role definitions; creation of new SoD rules.

SLOs and KPIs [Informative]

- JoinerProvisioning_p95 <= 15 m
- LeaverDisable_p95 <= 5 m
- MoverDelta_p95 <= 10 m
- SoDFalseBlockRate_30d <= 2 percent
- RollbackSuccessRate_7d >= 99 percent

Outputs index [Informative]

[OC-1 SCIMMutation], [OC-2 AccessChangeEvent], [OC-3 SoDViolation], [OC-4 SLABreachAlert], [OC-5 DeprovisionCertificate], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (C1) [Informative]

Model and training profile [Informative]

model_id=icam-text-model; temperature=0.1; max_tokens_out=700
 prompt_pack_id=icam-jml-v1 (role mapping rubric, SoD heuristics, SCIM mutation patterns)
 RAG: sources={role catalog repo, SoD policy index, HRIS schema, SCIM profiles};
 max_docs=8; min_similarity=0.78; citations required
 fine_tuning/adapters: none initially; eval gates on SoD precision/recall and mutation correctness
 guardrails: SCIM allowlist; deny admin role APIs; per-target scoped tokens; PII minimization on logs

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal (HRIS event, decisions, approvals, mutations), ttl=365d
 semantic_memory: namespaces=["roles","sod","hris-schema","scim-profiles"];
 embeddings=text-embedding-sec-v1; k=8
 durable_state_store: event-sourced journal; snapshot desired_state after verification
 consistency: exactly-once for SCIMMutation per target_user_id per op; at-least-once for AccessChangeEvent
 idempotency: per Output Contracts

Decision and routing logic [Informative]

role_set = f(department, job_title, location, employment_type)
 entitlements = union(role_entitlements[role_set]) minus ineligible_entitlements
 sod_conflict = intersects(entitlements, sod_blacklist[employee_id]) or

violates(sod_rules, entitlements)
provisioning_risk_score = 0.35sod_severity + 0.25role_delta_size + 0.2*(1 -
evidence_confidence) + 0.2*api_error_rate_1h
route = if sod_conflict then awaiting_approval else provisioning

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens, adversarial (role spoofing), jailbreak (escalation requests)]
thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below
red_team_cycle: monthly; seed with SoD edge cases and API failure chaos
rollback_policy: revert prompt_pack_id or model_id on eval_drop >= 1.5 percentage points for 48 h

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: derived_roles, entitlements_delta, SoD findings, approvals, evidence_refs, hashes
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL; retain request/response hashes, not full PII payloads

Incident Response Integration [Informative]

emit AccessChangeEvent to SIEM for anomaly correlation; raise IdentityAnomaly alerts on unexpected delta spikes or cross-tenant changes

Change Impact Assessment [Informative]

simulate entitlements_delta on staging tenant; if risk_score >= threshold → block/HITL; record results in journal

Stakeholder Feedback Loop [Informative]

ingest helpdesk/user feedback via OC-6; governance-reviewed updates adjust role heuristics and SoD hints (no auto-training on PII)

Data Sovereignty and Legal Hold [Informative]

enforce data_locality_policy by region; mask PII in events; legal_hold=true overrides TTL and purge; tag audit entries

Interfaces (links only) [Informative]

Consumes: HRIS Webhooks/REST; Role Catalog Git/REST
Produces: OC-1, OC-2, OC-3, OC-4, OC-5, OC-6 (as enabled)

Safety and abuse prevention [Informative]

kill_switch on repeated SCIM 5xx or signature mismatch; sandbox mode for high-risk movers; blast-radius caps (≤ 50 changes/5 min/tenant)

Testing and validation [Informative]

contract tests from Schema Capsules; offline replay of historical JML; chaos tests for API latency/failures; drift checks and rollback

Deployment and lifecycle [Informative]

HPA on queue depth; per-tenant concurrency caps; canary per target system; SBOM + attestations; sign outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (AC, IA, PS, CM); NIST SP 800-63; NIST SP 800-207; NIST CSF 2.0; ISO/IEC 27001/27002; SCIM RFC 7643/7644; CIS Controls v8; MITRE D3FEND (ACD, IAM patterns).

MCP-Native Protocol Specification (C1) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** HRIS Webhooks/REST; Role Model Catalog (Git/REST)
- **Native Protocol(s) Produced:** SCIM 2.0 mutations; Kafka AccessChange events
- **MCP Context Fields:**
 - **Required:** mission_id; role="IdentityProvisioningAgent"; intent="provision"; constraints=["timebox_15m"]; provenance.attestation
 - **Optional:** policy_refs (e.g., AC-2, IA-2), classification (C2), decision_basis
- **Enforcement Note:** PEPs must enforce timebox_15m, verify provenance on SCIM mutation, and block on unresolved SoD conflicts.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** authoritative native + MCP-wrapped HRIS and Role Catalog examples as above.

- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

C2. Auth Policy Agent

Agent Blueprint [Informative]

Purpose: Enforce MFA/passwordless and adaptive policies using risk/behavioral context; emit AuthDecision and push policy updates to IdP.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **UEBA Risk Signals (REST/Stream)** — `subject`, `risk_score`, anomalies (e.g., `impossible_travel`, `new_device`), `observed_at`, `explanations`.*
- **Device Posture (MDM/EDR REST)** — compliance state, encryption on/off, jailbreak/root, `secure_boot`, `last_checkin`.
- **IdP Auth Telemetry (REST/JSON or Syslog)** — sign-in context (`user/app/client/ip/asn/geo/time`), current IdP decision.

Model training / knowledge (what the LLM relies on):

- Prompt-pack for adaptive auth norms: NIST 800-63/63B AAL mapping, ZTA signals fusion, per-app sensitivity tiers.
- RAG sources: policy-as-code repo (IdP conditions/config), UEBA model documentation, device posture policy, ASN/geo reputation lists; do **not** train on raw PII—use `evidence_refs`.
- Guardrails: never override IdP deny; never downgrade required AAL; function scopes limited to **read** signals + **write** only to IdP policy endpoints and AuthDecision stream; strict allowlist of policy paths.

Decisions it makes (deterministic + model-assisted):

- **Risk fusion:** combine UEBA, device posture, and sign-in context to compute `combined_risk` (0–100).
- **Decision selection:** allow vs. `step_up` (MFA/passkey/WebAuthn) vs. deny, based on `combined_risk` and app sensitivity, with SoP caps (cannot “allow” when device noncompliant AND `UEBA_risk` $\geq$ critical).

- **Policy tuning:** propose or push per-app conditional rules (e.g., require WebAuthn for admin apps from high-risk geo).
- **Exception routing:** requests to bypass step-up require **HITL-stepup-exception** token.

Routing / where outputs go:

- **AuthDecision** → PDP/IdP gateway (synchronous, low-latency) for each sign-in attempt.
- **IdP Policy Updates** → IdP (REST/Graph/Config) for durable policy changes (rate-limited, with canary + rollback).
- **Tickets/alerts** → open on anomalous spikes, policy push failures, or repeated step-up exceptions.

Automation scope vs. manual/HITL:

- **Fully automated:** per-request AuthDecision; non-breaking policy updates within guardrail bounds; rollback on push failure.
- **HITL required:** step-up exceptions; any rule that decreases effective AAL for protected apps; geofence relaxations; ASN allowlisting.
- **Manual outside agent:** global auth strategy, AAL tier definitions, adjudication of contested risk model outputs.

Security Domain: ICAM (Identity, Credential, and Access Management)

Inputs (native protocols consumed) [Informative]

1. **UEBA Risk Signals (REST/Stream)** — risk score and anomaly context.
2. **Device Posture (MDM/EDR REST)** — compliance/encryption/jailbreak/secure boot.
3. **IdP Auth Telemetry (REST/JSON or Syslog)** — real-time sign-in events.

Example: Consumed Protocol — UEBA Risk Signals [Informative]

Native payload

```
{
  "subject": "E102993",
  "risk_score": 82,
  "signals": ["impossible_travel", "new_device"],
```

```
"observed_at": "2025-08-15T13:22:00Z",
"explanations": { "geo_delta_km": 4200, "device_fingerprint_change": true }
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-c2-ueba-1111-2222-3333-4444",
    "thread_id": "uuid-ueba-E102993-2025-08-15T13:22:00Z",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "AuthPolicyAgent",
    "intent": "govern",
    "policy_refs": ["IA-2", "AC-7", "SC-23"],
    "constraints": ["HITL-stepup-exception"],
    "decision_basis": {
      "evidence_refs": ["uri://ueba/events/E102993/2025-08-15T13:22:00Z"],
      "confidence": 0.9,
      "explanation_ref": "uri://models/risk/ueba-v1"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/icam/auth-policy-agent",
      "signing_kid": "kid-ueba-c2-01",
      "attestation_ref": "uri://slsa/attestations/auth-policy@sha256:ueba01"
    },
    "classification": "C2",
    "legal_hold": false
  },
}
```

```
"native_payload": { "...": "as above" }  
}
```

Example: Consumed Protocol — Device Posture (MDM/EDR REST) [Informative]

Native payload

```
{  
  "device_id": "dev-3f91",  
  "user_employee_id": "E102993",  
  "platform": "macOS",  
  "os_version": "14.5",  
  "compliance": "noncompliant",  
  "reasons": ["disk_encryption_disabled"],  
  "encryption": false,  
  "secure_boot": true,  
  "last_checkin": "2025-08-15T13:15:30Z"  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-c2-mdm-5555-6666-7777-8888",  
    "thread_id": "uuid-device-dev-3f91",  
    "task_id": "uuid-9911-8822-7733-6644",  
    "role": "AuthPolicyAgent",  
    "intent": "govern",  
    "policy_refs": ["IA-2", "CM-6", "SC-12"],  
    "constraints": ["HITL-stepup-exception"],  
    "decision_basis": {  
      "evidence_refs": ["uri://mdm/devices/dev-3f91"],  

```

```

    "confidence": 0.95,
    "explanation_ref": "uri://kb/auth/policy-conditions#device-posture"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/icam/auth-policy-agent",
    "signing_kid": "kid-mdm-c2-02",
    "attestation_ref": "uri://slsa/attestations/auth-policy@sha256:mdm02"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { "...": "as above" }
}

```

Example: Consumed Protocol — IdP Auth Telemetry [Informative]

Native payload

```

{
  "event_id": "signin-9a12",
  "user": "E102993",
  "app": "gcp-console",
  "client": "Chrome 125",
  "ip": "198.51.100.44",
  "asn": "AS15169",
  "geo": "US-CA",
  "time": "2025-08-15T13:22:05Z",
  "decision": "challenge_mfa"
}

```

MCP-wrapped payload

```

{

```

```

"mcp_context": {
  "mcp_version": "0.9",
  "mission_id": "uuid-c2-idp-aaaa-bbbb-cccc-dddd",
  "thread_id": "uuid-signin-signin-9a12",
  "task_id": "uuid-1122-3344-5566-7788",
  "role": "AuthPolicyAgent",
  "intent": "govern",
  "policy_refs": ["IA-2", "AC-7"],
  "constraints": ["HITL-stepup-exception"],
  "decision_basis": {
    "evidence_refs": ["uri://idp/signin/signin-9a12"],
    "confidence": 0.93,
    "explanation_ref": "uri://kb/auth/adaptive-mfa#risk-geo-device"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/icam/auth-policy-agent",
    "signing_kid": "kid-idp-c2-03",
    "attestation_ref": "uri://slsa/attestations/auth-policy@sha256:idp03"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { "...": "as above" }
}

```

Outputs (native) [Informative]

- **AuthDecision** (allow/deny/step-up) per sign-in.
- **IdP Policy Updates** (REST/Graph/Config) for adaptive rules and AAL requirements.

MCP context (required) [Informative]

mission_id; role="AuthPolicyAgent"; intent="govern"; policy_refs=["AC-7","IA-2","IA-5"]; constraints=["HITL-stepup-exception"]; provenance.attestation (SLSA/SPIFFE + KID)

MCP context (optional) [Informative]

classification (C1–C3); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

PEPs/IdP must: (1) verify provenance.attestation on AuthDecision; (2) honor **HITL-stepup-exception** token for temporary bypass; (3) block any decrease in AAL for protected apps without HITL.

NIST SP 800-160v2 linkage [Informative]

Implement/Maintain — adaptive defenses with diversified sensing and dynamic reconfiguration; aligns to NIST 800-207 (ZTA signal fusion).

Automation feasibility [Informative]

High (deterministic thresholds with model-assisted risk fusion; exceptions remain HITL).

Output Contracts (merged) [Informative]

OC-1: AuthDecision (allow/deny/step-up) [Informative]

- **Producer(s):** C2
- **Topic/Path:** PDP stream auth.decision.v1 or IdP decision hook
- **Schema/Format:** JSON {decision, aal_required, reasons[], evidence_refs[], ttl_s, user, app, client, ip, geo, asn}
- **Classification:** C2
- **Delivery:** exactly-once per event_id (consumer enforces)
- **Ordering:** per user
- **Idempotency-Key:** sha256(event_id)
- **Ack/Nack:** gateway ACK <= 200 ms else retry (bounded)
- **Timeouts/Retry:** decision_latency_budget <= 250 ms; retry<=2 (shadow-allow for low-risk only)
- **Side-Effects:** attach decision_rationale_url to IdP session; emit audit record

- **HITL Token:** required to override step-up/deny for protected apps
- **Observability:** trace_id, mission_id, policy_refs, combined_risk, classification_label, provenance.attestation
- **Retention/TTL:** 1 year (minimized PII)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=AuthDecision@1.0 | json_schema_uri=uri://schema/auth-decision-1.0.json | sha256= | producers=C2 | consumers=IdP-Gateway-01 | accepts=1.0–1.x

Conformance: Normative.

OC-2: IdPPolicyUpdate (adaptive rules) [Informative]

- **Producer(s):** C2
- **Topic/Path:** IdP config API (e.g., /policies/conditional_access/rules)
- **Schema/Format:** JSON Patch/Graph mutations; changeset includes rule_id, matchers, action (require_webauthn, block, step_up_mfa), scope, canary_id, rollback_token
- **Classification:** C1
- **Delivery:** at-least-once
- **Ordering:** per rule_id
- **Idempotency-Key:** sha256(rule_id, changeset_hash)
- **Ack/Nack:** 2xx ACK; 4xx/5xx NACK → retry/backoff; on repeated failure auto-rollback
- **Timeouts/Retry:** ack≤5s; exp-backoff≤5x
- **Side-Effects:** canary rollout 10 percent → 50 percent → 100 percent; rollback on spike in deny/error
- **HITL Token:** required when change reduces AAL or widens geo/asn allowlist
- **Observability:** trace_id, mission_id, decision_basis.summary_ref, canary_metrics_ref
- **Retention/TTL:** 7 years (policy diffs + signatures)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When IdP config API integration is enabled
schema_id=IdPPolicyUpdate@1.0 | json_schema_uri=uri://schema/idp-policy-update-1.0.json | sha256= | producers=C2 | consumers=IdP-Config-01 | accepts=1.0–1.x
Conformance: Normative when condition is met.

OC-3: StepUpExceptionRequest (HITL) [Informative, optional]

- **Producer(s):** C2, Approver-Portal-01
- **Topic/Path:** auth.stepup.exception.request
- **Schema/Format:** JSON {event_id, user, app, reason, duration_s, risk_factors[], evidence_refs[]}
- **Requirement Level:** Optional
- **Condition:** When exception workflow is enabled
- **Side-Effects:** open HITL approval; temporary allow if approved with bounded TTL

Schema Capsule (OC-3) [Normative]

schema_id=StepUpExceptionRequest@1.0 | json_schema_uri=uri://schema/stepup-exception-1.0.json

OC-4: AuthAnomalyEvent (SIEM) [Informative, optional]

- **Producer(s):** C2
- **Topic/Path:** auth.anomaly.v1
- **Schema/Format:** JSON {pattern, count_5m, threshold, top_asn[], top_geo[]}
- **Requirement Level:** Optional
- **Condition:** When SIEM/IR integration is present

Schema Capsule (OC-4) [Normative]

schema_id=AuthAnomalyEvent@1.0 | json_schema_uri=uri://schema/auth-anomaly-1.0.json

State machine (concise) [Informative]

states = { idle, ingesting_signals, correlating_context, deciding, step_up, deny, allow, updating_policy, awaiting_exception_approval, contestation_workflow, failed, closed }

transition(idle -> ingesting_signals) on UEBA/MDM/IdP event
 transition(ingesting_signals -> correlating_context) when all required signals present or stale_ok=true
 transition(correlating_context -> deciding) when context fused
 transition(deciding -> allow) if action=allow
 transition(deciding -> step_up) if action=step_up
 transition(deciding -> deny) if action=deny
 transition(deciding -> updating_policy) when pattern requires durable rule change
 transition(step_up -> awaiting_exception_approval) on exception request
 transition(updating_policy -> closed) when canary->100 percent and metrics healthy
 transition(* -> contestation_workflow) when dispute opened (policy or model)
 transition(* -> failed) on timeout or validation error

 timeout(deciding, 200 ms) -> step_up (safe default)
 idempotency_key = sha256(event_id) for AuthDecision; sha256(rule_id, changeset_hash) for IdPPolicyUpdate

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 AuthDecision	Required	Always	Real-time access control
OC-2 IdPPolicyUpdate	Conditionally Required	IdP config API integration enabled	Durable adaptive policy enforcement
OC-3 StepUpExceptionRequest	Optional	Exception workflow enabled	Governance/HITL control
OC-4 AuthAnomalyEvent	Optional	SIEM/IR integration present	Incident readiness & detection

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- `policy_refs`: IA-2 (I&A), IA-5 (Authenticator Management), AC-7 (Unsuccessful Login Attempts), SC-23 (Session Authenticity).
- **HITL required**: step-up bypasses; rules that reduce AAL; geo/asn allowlist expansions; device posture relaxations.
- **Automatic HITL escalation triggers**: `model_confidence < theta_low`;
`model_drift_detected = true`; `anomaly_spike >= threshold`;
`contested_decision=true`.

SLOs and KPIs [Informative]

- `DecisionLatency_p95 <= 250 ms`
- `PolicyUpdateAck_p95 <= 5 s`
- `FalseAllowRate_30d <= 0.5 percent`
- `FalseDenyRate_30d <= 1.0 percent`
- `StepUpCompletionRate_p95 >= 98 percent`

Outputs index [Informative]

[OC-1 AuthDecision], [OC-2 IdPPolicyUpdate], [OC-3 StepUpExceptionRequest], [OC-4 AuthAnomalyEvent]

Technical Implementation Details (C2) [Informative]

Model and training profile [Informative]

`model_id=auth-policy-text-model`; `temperature=0.1`; `max_tokens_out=500`
`prompt_pack_id=auth-adaptive-v1` (AAL mapping, risk fusion rules, examples)
RAG: `sources={policy-as-code, UEBA docs, device posture policy, ASN/geo reputation}`;
`max_docs=8`; `min_similarity=0.78`; citations required
`fine_tuning/adapters: none initially`; eval gates on decision accuracy and AAL
conformance
guardrails: deny downgrade of AAL; no token minting; bounded change scope; rate-limit
policy pushes

Memory and state [Informative]

`working_memory.max_tokens=3k`; `eviction=recency_then_importance`
`episodic_memory`: per `mission_id` journal of decisions, inputs, and outcomes; `ttl=365d`

semantic_memory: namespaces=["policy","risk-models","devices","asn-geo"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced; snapshots at policy canary flips
consistency: exactly-once for AuthDecision per event_id; at-least-once for
IdPPolicyUpdate
idempotency: per Output Contracts

Decision and routing logic [Informative]

Normalize inputs to [0,100]:

- $ueba = \min(100, risk_score)$
- $device_risk = 100$ if noncompliant else 0; +20 if encryption=false; +15 if jailbreak/root=true
- app_sensitivity in {low=20, med=50, high=80, admin=95}
- $geo_velocity = \text{clip}(geo_delta_km / 1000 * 10, 0, 100)$
- $asn_rep = reputation_score$ (0=good, 100=bad)

$combined_risk = 0.4ueba + 0.25device_risk + 0.2app_sensitivity + 0.1geo_velocity + 0.05*asn_rep$

Decision thresholds:

- if $device_risk \geq 80$ and $ueba \geq 70$ then action = deny
- else if $combined_risk \geq 60$ or anomaly in {"impossible_travel","new_device"} then action = step_up ($aal_required \geq policy_min_aal$)
- else action = allow

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens, adversarial sign-ins, bypass attempts]
thresholds: eval_pass_rate ≥ 99.5 percent → auto_HITL if below
red_team_cycle: monthly ATT&CK-inspired auth probes
rollback_policy: revert prompt_pack_id/model_id on eval_drop ≥ 1.5 percentage points for 48 h

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: inputs (ueba, device, idp), combined_risk, rule_hit, aal_required, evidence_refs; signed hashes
UI/API: expose classification_label, provenance.attestation, decision_rationale_url

Incident Response Integration [Informative]

emit AuthAnomalyEvent (OC-4) to SIEM; correlate with failed step-up storms, ASN spikes, or geo pivoting

Change Impact Assessment [Informative]

simulate IdPPolicyUpdate on shadow tenant; capture completion/error/UX deltas; block rollout if deny spike > threshold

Stakeholder Feedback Loop [Informative]

ingest approver feedback on exceptions; adjust rubric after governance review; no auto-training on PII

Data Sovereignty and Legal Hold [Informative]

PII minimization; region-scoped processing; legal_hold=true overrides TTL and purge

Interfaces (links only) [Informative]

Consumes: UEBA Risk Signals; Device Posture (MDM/EDR); IdP Auth Telemetry
Produces: OC-1, OC-2, OC-3, OC-4 (as enabled)

Safety and abuse prevention [Informative]

kill_switch on signature/provenance mismatch; blast-radius cap on policy pushes; cost/QPS limits; sandbox mode for rule changes

Testing and validation [Informative]

contract tests from Schema Capsules; offline replay of sign-in weeks; chaos tests (latency/partial outages); drift checks and rollback

Deployment and lifecycle [Informative]

HPA on decision QPS; concurrency caps; canary + rollback; SBOM + attestations; sign outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-63/63B; NIST SP 800-207 (ZTA); NIST SP 800-53 Rev. 5 (IA, AC, SC); ISO/IEC 27001/27002; FIDO2/WebAuthn; CIS Controls v8.

MCP-Native Protocol Specification (C2) [Normative]

- **Native Protocol(s) Consumed:** UEBA Risk Signals (REST/Stream); Device Posture (MDM/EDR REST); IdP Auth Telemetry (REST/JSON or Syslog)

- **Native Protocol(s) Produced:** IdP Policy Updates (REST/Graph/Config API); AuthDecision (allow/deny/step-up)
- **MCP Context Fields:**
 - **Required:** mission_id; role="AuthPolicyAgent"; intent="govern"; policy_refs=["AC-7","IA-2","IA-5"]; constraints=["HITL-stepup-exception"]; provenance.attestation
 - **Optional:** classification (C1–C3); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold
- **Enforcement Note:** PDP/PEP must verify provenance, enforce AAL floors, and require HITL token for step-up exceptions.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL.
- **Example payloads:** native + MCP-wrapped UEBA, MDM/EDR, and IdP telemetry above; plus OC-1/OC-2 schemas in Capsules.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

C3. Access Control Agent

Agent Blueprint [Informative]

Purpose: Compile and push RBAC/ABAC/PBAC policies to IAM/PDP/PEP; ensure traceability to 800-53 AC controls.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Role Engineering Inputs (IGA/Mining REST)** — candidate roles, membership rules, seed users, role risk.
- **Entitlement Models (SaaS/IAM REST/Graph)** — resource → actions/conditions; SoD conflicts; sensitivity.
- **Policy Source Repo (Git/REST)** — Rego/XACML/PBAC modules; policy-as-code and tests.

Model training / knowledge (what the LLM relies on):

- Prompt-pack for least-privilege design, SoD patterns, AC control mappings, policy idioms (Rego/XACML).
- RAG: role-mining guidance, entitlement catalogs, prior bundles, policy test corpus; do **not** train on regulated PII—use evidence_refs.
- Guardrails: write access limited to policy repos and bundle registries; “deny by default” scaffolds; cannot widen prod scope without constraints token.

Decisions it makes (deterministic + model-assisted):

- **Role curation:** accept/reject candidate roles from IGA; compute role_risk and blast_radius.
- **Policy synthesis:** translate role and entitlement models into RBAC/ABAC/PBAC rules; normalize to target language.
- **SoD enforcement:** detect policy conflicts (e.g., FIN_AP_REQUESTOR vs FIN_AP_APPROVER); **block or HITL**.
- **Compilation & verification:** compile bundles; run unit/regression tests and reachability checks; sign artifacts.
- **Rollout strategy:** canary → staged rollout → full; rollback on error/deny spikes.

Routing / where outputs go:

- **OPA/XACML bundles** → PDPs/PEPs or policy registries (OCI/HTTP).
- **IdP group/attribute updates** → reflect role membership and attributes that policies rely on.
- **Tickets/alerts** → open on SoD blocks, failed tests, rollout anomalies.

Automation scope vs. manual/HITL:

- **Fully automated:** draft/compile/test/sign/publish to staging; non-privileged scope changes; sync IdP groups/attributes referenced by approved policies.
- **HITL required:** any policy that grants prod-write on CrownJewels; SoD overrides; wildcard resources/actions; geo/tenant expansion.
- **Manual outside agent:** new SoD frameworks; cross-business entitlement taxonomy design.

Security Domain: ICAM (Identity, Credential, and Access Management)

Inputs (native protocols consumed) [Informative]

1. **Role Engineering Inputs (IGA/Mining REST)** — candidate roles and membership rules.
2. **Entitlement Models (SaaS/IAM REST/Graph)** — authorization graph slices.
3. **Policy Source Repo (Git/REST)** — Rego/XACML modules and tests.

Example: Consumed Protocol — Role Engineering Inputs (IGA/Mining REST)

[Informative]

Native payload

```
{
  "candidate_role_id": "FIN_AP_APPROVER",
  "membership_rule": "dept == 'Finance' AND title in ['Manager','Director']",
  "seed_users": ["E100211","E100337","E100441"],
  "risk_score": 0.72,
  "owner": "finance.ops"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-c3-re-1111-2222-3333-4444",
    "thread_id": "uuid-role-cand-FIN_AP_APPROVER",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "AccessControlAgent",
    "intent": "govern",
    "policy_refs": ["AC-2", "AC-5", "AC-6"],
    "decision_basis": {
      "evidence_refs": ["uri://iga/candidate_roles/FIN_AP_APPROVER"],
      "confidence": 0.9,
      "explanation_ref": "uri://kb/icam/role-mining-risk-eval"
    }
  }
}
```

```

},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/icam/access-control-agent",
  "signing_kid": "kid-iga-c3-01",
  "attestation_ref": "uri://slsa/attestations/access-control@sha256:iga01"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "as above" }
}

```

Example: Consumed Protocol — Entitlement Models (SaaS/IAM REST/Graph)

[Informative]

Native payload

```

{
  "resource": "erp.ap.invoices",
  "actions": ["view","approve","export"],
  "conditions": [
    {"attribute": "amount_usd", "op": "<=", "value": 50000},
    {"attribute": "region", "op": "in", "value": ["US","CA","UK"]}
  ],
  "risk": {"sensitivity": "HIGH", "sod_conflicts": ["FIN_AP_REQUESTOR"]}
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-c3-ent-5555-6666-7777-8888",

```

```

"thread_id": "uuid-ent-erp.ap.invoices",
"task_id": "uuid-9911-8822-7733-6644",
"role": "AccessControlAgent",
"intent": "govern",
"policy_refs": ["AC-3", "AC-4", "AC-6"],
"decision_basis": {
  "evidence_refs": ["uri://iam/entitlements/resources/erp.ap.invoices"],
  "confidence": 0.92,
  "explanation_ref": "uri://kb/icam/pbac-conditions"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/icam/access-control-agent",
  "signing_kid": "kid-ent-c3-02",
  "attestation_ref": "uri://slsa/attestations/access-control@sha256:ent02"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "as above" }
}

```

Example: Consumed Protocol — Policy Source Repo (Git/REST) [Informative]
 Native payload (Rego module)

```
package authz.erp.ap
```

```
default allow = false
```

```
allow {
  input.action == "approve"
}
```

```
input.resource == "erp.ap.invoices"
input.attrs.amount_usd <= 50000
input.subject.roles[_] == "FIN_AP_APPROVER"
input.attrs.region == "US"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-c3-git-aaaa-bbbb-cccc-dddd",
    "thread_id": "uuid-opa-bundle-authz.erp.ap",
    "task_id": "uuid-1122-3344-5566-7788",
    "role": "AccessControlAgent",
    "intent": "govern",
    "policy_refs": ["AC-3", "AC-4", "AC-6"],
    "constraints": ["no-prod-without-2-approvals"],
    "decision_basis": {
      "evidence_refs": ["uri://git/policy/opa/authz.erp.ap.rego@v3.1.0"],
      "confidence": 0.98,
      "explanation_ref": "uri://kb/icam/policy-compilation#opa"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/icam/access-control-agent",
      "signing_kid": "kid-git-c3-03",
      "attestation_ref": "uri://slsa/attestations/access-control@sha256:git03"
    },
    "classification": "C2",
  }
}
```

```

    "legal_hold": false
  },
  "native_payload": "package authz.erp.ap\n\ndefault allow = false\n\nallow {...}"
}

```

Outputs (native) [Informative]

- **OPA/XACML bundles** to PDPs/PEPs or registries (signed).
- **IdP group/attribute updates** to maintain policy prerequisites (role groups, user attributes).

MCP context (required) [Informative]

mission_id; role="AccessControlAgent"; intent="govern"; policy_refs=["AC-*"];
provenance.attestation (SLSA/SPIFFE + KID)

MCP context (optional) [Informative]

constraints (e.g., "no-prod-without-2-approvals"); classification (C1–C3); decision_basis

Enforcement note [Informative]

PEPs/PDPs must verify bundle signatures, enforce accepted version ranges, and refuse unsigned or unregistered producers; prod rollouts require constraint satisfaction.

NIST SP 800-160v2 linkage [Informative]

Implement/Maintain — enforceable, analyzable access policies with assured provenance and rollback paths.

Automation feasibility [Informative]

High (deterministic compilers + static analysis + canary rollout; HITL for privileged expansions).

Output Contracts (merged) [Informative]

OC-1: PolicyBundlePublish (OPA/XACML) [Informative]

- **Producer(s)**: C3
- **Topic/Path**: oci://policy-registry/<org>/<bundle>:<ver> or HTTPS PDP /bundles
- **Schema/Format**: OPA bundle or XACML package; manifest + module digests; signature + SBOM

- **Classification:** C1
- **Delivery:** at-least-once
- **Ordering:** per bundle_id
- **Idempotency-Key:** sha256(bundle_id, version)
- **Ack/Nack:** 201 Created or PDP ACK; NACK on schema/signature/compat failure
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; auto-rollback on failed smoke tests
- **Side-Effects:** update registry index; append attestation to audit; notify PDP fleet
- **HITL Token:** required when bundle widens prod scope or introduces wildcard actions
- **Observability:** trace_id, mission_id, policy_refs, tests_ref, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=PolicyBundle@1.0 | json_schema_uri=uri://schema/policy-bundle-1.0.json | sha256= | producers=C3 | consumers=PDP-01, PEP-01 | accepts=1.0–1.x

Conformance: Normative.

OC-2: IdPGroupAttributeUpdate [Informative]

- **Producer(s):** C3
- **Topic/Path:** IdP Graph/SCIM endpoints for groups/attributes
- **Schema/Format:** JSON Patch / SCIM {op, path, value}; signed change-set with reason codes
- **Classification:** C2 (limited PII)
- **Delivery:** exactly-once per target principal per op (consumer enforces)
- **Ordering:** per principal_id
- **Idempotency-Key:** sha256(target_system, principal_id, op, version_floor_60s)
- **Ack/Nack:** 2xx ACK; 4xx/5xx NACK → retry/backoff; ticket on repeated NACK
- **Timeouts/Retry:** ack<=15s; exp-backoff<=5x

- **Side-Effects:** sync identity graph; trigger policy re-eval caches
- **HITL Token:** required for privileged group grants in prod
- **Observability:** trace_id, mission_id, decision_basis.summary_ref, provenance.attestation
- **Retention/TTL:** 7 years (hashes + rationale)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When policies depend on IdP groups/attributes and synchronization is enabled

schema_id=IdPGroupAttributeUpdate@1.0 | json_schema_uri=uri://schema/idp-group-attr-update-1.0.json | sha256= | producers=C3 | consumers=IdP-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: PolicyCompilationReport [Informative, optional]

- **Producer(s):** C3
- **Topic/Path:** icam.policy.compile.report
- **Schema/Format:** JSON {bundle_id, tests_passed, coverage, unreachable_rules[], risk_summary}
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per bundle_id
- **Idempotency-Key:** sha256(bundle_id, version)
- **Ack/Nack:** report_id assigned; retry/backoff
- **Side-Effects:** gate promotion to staging/prod
- **HITL Token:** none
- **Observability:** trace_id, mission_id, tests_ref
- **Retention/TTL:** 2 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When compile-time QA gating is enabled

schema_id=PolicyCompilationReport@1.0 | json_schema_uri=uri://schema/policy-compile-report-1.0.json

OC-4: PolicyDriftAlert [Informative, optional]

- **Producer(s):** C3
- **Topic/Path:** icam.policy.drift
- **Schema/Format:** JSON {policy_id, expected_digest, observed_digest, drift_detected_at, impact_estimate}
- **Classification:** C1
- **Delivery/Ordering:** at-least-once
- **Idempotency-Key:** sha256(policy_id, observed_digest)
- **Ack/Nack:** alert_id assigned; retry/backoff
- **Side-Effects:** freeze rollout; open incident if prod
- **HITL Token:** none
- **Observability:** trace_id, mission_id
- **Retention/TTL:** 1 year

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When continuous policy attestation is enabled

schema_id=PolicyDriftAlert@1.0 | json_schema_uri=uri://schema/policy-drift-1.0.json

OC-5: SoDConflictPolicyBlock [Informative, optional]

- **Producer(s):** C3
- **Topic/Path:** icam.sod.block
- **Schema/Format:** JSON {policy_id, conflicts_with[], severity, required_actions[]}
- **Classification:** C2
- **Delivery/Ordering:** at-least-once
- **Idempotency-Key:** sha256(policy_id, conflicts_hash)
- **Ack/Nack:** case_id assigned; retry/backoff
- **Side-Effects:** block promotion; request approvals
- **HITL Token:** required to override
- **Observability:** trace_id, mission_id, decision_rationale_url

- **Retention/TTL:** 7 years

Schema Capsule (OC-5) [Normative]

Requirement Level: Optional

Condition: When SoD governance workflow is enabled

schema_id=SoDConflictPolicyBlock@1.0 | json_schema_uri=uri://schema/sod-conflict-policy-block-1.0.json

State machine (concise) [Informative]

states = { idle, ingesting_models, synthesizing, compiling, testing, signing, canary, rolling_out, monitoring, rolled_back, contestation_workflow, failed, closed }

transition(idle -> ingesting_models) on new IGA/entitlement/repo update

transition(ingesting_models -> synthesizing) when inputs validated

transition(synthesizing -> compiling) when policy graph stable

transition(compiling -> testing) on successful build

transition(testing -> signing) when unit/regression/reachability pass

transition(signing -> canary) when signatures/attestations complete

transition(canary -> rolling_out) when canary healthy

transition(rolling_out -> monitoring) when rollout hits 100 percent

transition(* -> rolled_back) on deny/error spike or incompatibility

transition(* -> contestation_workflow) when SoDConflictPolicyBlock raised

transition(* -> failed) on timeout/validation error

timeout(testing, 120s) -> failed; retry<=3 with exp backoff

idempotency_key = sha256(bundle_id, version) for PolicyBundlePublish;

sha256(target_system, principal_id, op, version_floor_60s) for IdP updates

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 PolicyBundlePublish	Required	Always	Enforceable policy distribution
OC-2 IdPGroupAttributeUpdate	Conditionally Required	Policies depend on IdP groups/attributes and sync is enabled	Identity-policy consistency

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-3 PolicyCompilationReport	Optional	Compile-time QA gating enabled	Quality gate/traceability
OC-4 PolicyDriftAlert	Optional	Continuous policy attestation enabled	Integrity monitoring
OC-5 SoDConflictPolicyBlock	Optional	SoD governance workflow enabled	Risk control & governance

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: AC-2, AC-3, AC-4, AC-5, AC-6, AC-16 (plus internal SoD).
- **HITL required:** prod scope expansions; wildcard resource/action; SoD override; cross-tenant or cross-region expansions.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; deny_spike > threshold; coverage_drop > threshold.
- **Manual outside agent:** meta-model changes (new policy language features); enterprise-wide taxonomy shifts.

SLOs and KPIs [Informative]

- BundlePublishAck_p95 <= 60 s
- PolicyTestPassRate >= 99.9 percent
- RollbackTime_p95 <= 2 min
- DriftMTTD <= 15 min
- SoDOverrideRate_30d <= 1 percent

Outputs index [Informative]

[OC-1 PolicyBundlePublish], [OC-2 IdPGroupAttributeUpdate], [OC-3 PolicyCompilationReport], [OC-4 PolicyDriftAlert], [OC-5 SoDConflictPolicyBlock]

Technical Implementation Details (C3) [Informative]

Model and training profile [Informative]

model_id=access-policy-text-model; temperature=0.1; max_tokens_out=700
prompt_pack_id=rbac-abac-pbac-v1 (least-privilege, SoD patterns, language idioms)
RAG: sources={policy repo, entitlement graph, IGA role corpus, test suites};
max_docs=8; min_similarity=0.78; citations required
fine_tuning/adapters: none initially; eval gates on compile success, test pass, and reachability metrics
guardrails: deny prod-widening without constraint token; limit to approved registries/tenants

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal (inputs, diffs, tests, rollouts), ttl=365d
semantic_memory: namespaces=["roles","entitlements","policies","tests"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced; snapshot at each published version
consistency: at-least-once (bundle publish); exactly-once (IdP group/attr per principal/op)
idempotency: per Output Contracts

Decision and routing logic [Informative]

$role_risk = 0.5risk_score + 0.3blast_radius + 0.2 \cdot (1 - evidence_confidence)$
 $policy_change_risk = 0.4resource_sensitivity + 0.3diff_scope + 0.2SoD_severity + 0.1test_regressions$
route = if SoD_severity >= high then contestation_workflow else (policy_change_risk >= threshold ? canary : rolling_out)

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[compile_goldens, reachability, SoD adversarials]
thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below
red_team_cycle: monthly policy-bypass probes
rollback_policy: revert to last good bundle on deny_spike > threshold or coverage_drop > threshold for 10 min

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

decision_rationale_template: diffs, tests_passed, coverage, SoD analysis, evidence_refs, hashes
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL with stable fields; retain artifact digests, not full datasets

Incident Response Integration [Informative]

emit PolicyDriftAlert to SIEM; correlate with access anomalies; auto-open incident for prod drift

Change Impact Assessment [Informative]

simulate bundle against shadow PDP; compute allow/deny deltas by resource/action; block rollout if deny spike or unintended allow

Stakeholder Feedback Loop [Informative]

ingest review feedback; update prompt_pack/test corpus after governance review; never auto-train on PII

Data Sovereignty and Legal Hold [Informative]

region-scoped registries; legal_hold=true overrides TTL; provenance maintained

Interfaces (links only) [Informative]

Consumes: IGA/Mining REST; SaaS/IAM Entitlement Graph; Policy Repo (Git/REST)
Produces: OC-1, OC-2, OC-3, OC-4, OC-5 (as enabled)

Safety and abuse prevention [Informative]

kill_switch on signature or compatibility failure; blast-radius caps; rate limits; sandbox canary mode

Testing and validation [Informative]

contract tests from Schema Capsules; conftest/opa test suites; XACML PDP regression; chaos in rollout

Deployment and lifecycle [Informative]

HPA on compile queue depth; canary then progressive rollout; SBOM and attestations; sign outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (AC family); NIST SP 800-207 (ZTA); ISO/IEC 27001/27002; OPA/Rego; XACML; Zanzibar-style relationship models; MITRE D3FEND.

MCP-Native Protocol Specification (C3) [Normative]

- **Native Protocol(s) Consumed:** Role Engineering Inputs (IGA/Mining REST); Entitlement Models (SaaS/IAM REST/Graph); Policy Source Repo (Git/REST)
- **Native Protocol(s) Produced:** OPA/XACML bundles to PDPs/PEPs; IdP group/attribute updates
- **MCP Context Fields:**
 - **Required:** mission_id; role="AccessControlAgent"; intent="govern"; policy_refs=["AC-*"]; provenance.attestation
 - **Optional:** constraints (e.g., "no-prod-without-2-approvals"); classification; decision_basis
- **Enforcement Note:** PDP/PEP must validate signatures and accepted ranges; prod deployments require constraint checks and, where applicable, HITL tokens.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** native + MCP-wrapped IGA, Entitlement, and Git examples above (authoritative).
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is [Normative] and, together with each **Schema Capsule**, defines testable requirements.

C4. Privileged Session Monitor Agent

Agent Blueprint [Informative]

Purpose: Monitor and record privileged sessions (PAM/PSM/SSM/Teleport/etc.), analyze keystroke/command activity in near real time, and auto-flag anomalies for review.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **PAM Telemetry (REST/Webhook/Syslog)** — session lifecycle (start/stop), actor identity, target host/account, approvals/ticket, recording references, protocol, JIT flags.

- **Keystroke / Command Logs (NDJSON/REST/gRPC)** — per-command stream with timestamps, exit codes, tty, user; optional screen/clipboard/file ops.

Model training / knowledge (what the LLM relies on):

- Prompt-pack for privileged behavior baselines (DBA, SRE, Win/Unix admin), change-ticket linkage rules, escalation windows, MITRE ATT&CK/TTP patterns.
- RAG sources: command/registry catalogs, historical approved sessions, allow/deny lists, parser grammars, policy exceptions; do **not** train on raw recordings—use evidence_refs and store hashes only.
- Guardrails: read-only access to raw recordings; write operations limited to Kafka/AMQP topics, case APIs, and object storage manifests; hard block on “de-recorded” sessions when session_recording_required is active.

Decisions it makes (deterministic + model-assisted):

- **Session validation:** verify ticket/approval present, recording_ref resolvable, actor→account mapping allowed, protocol in allowlist.
- **Anomaly scoring:** compute anomaly_score from rarity of commands, escalation context, off-hours use, scope of change, policy mismatches.
- **Response selection:** none (log only) vs. flag (create PrivilegedAnomaly) vs. **real-time block** request (terminate/session lock) when severity >= threshold and realtime_block:true.
- **Snapshotting:** emit periodic **SessionSnapshot** with rolling digests and top features during long-running sessions.
- **Classification:** default **C3** for privileged session data; raise legal_hold for flagged sessions.

Routing / where outputs go:

- **Kafka/AMQP** → PrivilegedAnomaly, SessionSnapshot topics for SOC/SIEM and case automation.
- **REST/gRPC** → DFIR/Case Mgmt (create/update case with pointers to evidence).
- **Object Storage** → append-only artifacts (transcripts, key digests, signatures) tagged with retention and legal_hold.

Automation scope vs. manual/HITL:

- **Fully automated:** ingestion/parsing, baseline checks, scoring, anomaly eventing, artifact hashing and storage, periodic snapshots.

- **HITL required:** any punitive action (kill/lock session), role removal, sanctioning user; classification downgrades; closing cases marked high-severity.
- **Manual outside agent:** tuning organization-specific “danger command” lists; writing DFIR playbooks; adjudicating contested cases.

Security Domain: Identity, Credential, and Access Management (ICAM)

Inputs (native protocols consumed) [Informative]

1. **PAM Telemetry (REST/Webhook/Syslog)** — session start/stop, approvals, recording references.
2. **Keystroke / Command Logs (NDJSON/REST/gRPC)** — command stream with timing and exit codes.

Example: Consumed Protocol — PAM Telemetry (Session Start) [Informative]

Native payload

```
{
  "event_type": "session_start",
  "session_id": "pam-ssn-00891",
  "user": "dbadmin",
  "actor_employee_id": "E100337",
  "target_host": "db-prd-01",
  "target_account": "oracle",
  "protocol": "ssh",
  "ticket_ref": "CHG0054421",
  "approved_by": ["ops.manager", "security.lead"],
  "recording_ref": "s3://pam-recordings/pam-ssn-00891.tlog",
  "started_at": "2025-08-15T14:05:11Z",
  "jit_elevation": true
}
```

MCP-wrapped payload

```
{
```

```

"mcp_context": {
  "mcp_version": "0.9",
  "mission_id": "uuid-c4-pam-1111-2222-3333-4444",
  "thread_id": "uuid-session-pam-ssn-00891",
  "task_id": "uuid-aa11-bb22-cc33-dd44",
  "role": "PrivilegedSessionMonitorAgent",
  "intent": "monitor",
  "policy_refs": ["AC-2", "AC-6", "AU-2", "AU-12"],
  "classification": "C3",
  "constraints": ["session_recording_required", "notify_owner:on_flag"],
  "decision_basis": {
    "evidence_refs": ["uri://pam/sessions/pam-ssn-00891/start"],
    "confidence": 0.99,
    "explanation_ref": "uri://kb/psm/session-context"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/icam/priv-session-monitor-agent",
    "signing_kid": "kid-pam-c4-01",
    "attestation_ref": "uri://slsa/attestations/psm@sha256:pam01"
  },
  "legal_hold": false
},
"native_payload": { "...": "as above" }
}

```

Example: Consumed Protocol — Keystroke / Command Logs [Informative]

Native payload

```

{
  "session_id": "pam-ssn-00891",

```

```

"timestamp": "2025-08-15T14:07:42Z",
"tty": "pts/2",
"type": "command",
"user": "dbadmin",
"command": "sudo usermod -aG dba appsvc",
"exit_code": 0
}
MCP-wrapped payload (flagged, legal_hold=true)
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-c4-cmd-5555-6666-7777-8888",
    "thread_id": "uuid-session-pam-ssn-00891",
    "task_id": "uuid-9911-8822-7733-6644",
    "role": "PrivilegedSessionMonitorAgent",
    "intent": "monitor",
    "policy_refs": ["AC-6", "AU-6", "AU-12"],
    "classification": "C3",
    "constraints": ["realtime_block:true", "notify_owner:on_flag"],
    "decision_basis": {
      "evidence_refs": ["uri://psm/logs/pam-ssn-00891/2025-08-15T14:07:42Z"],
      "confidence": 0.92,
      "explanation_ref": "uri://models/psm/anomaly-rules#role-escalation-outside-window"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/icam/priv-session-monitor-agent",
      "signing_kid": "kid-cmd-c4-02",

```

```

    "attestation_ref": "uri://slsa/attestations/psm@sha256:cmd02"
  },
  "legal_hold": true
},
"native_payload": { "...": "as above" }
}

```

Outputs (native) [Informative]

- **Kafka/AMQP:** PrivilegedAnomaly, SessionSnapshot.
- **REST/gRPC (optional):** Case handoff to DFIR/Case Mgmt.
- **Object Storage:** session artifacts (transcripts, rolling digests, signatures) with retention and legal_hold tags.

MCP context (required) [Informative]

mission_id; role="PrivilegedSessionMonitorAgent"; intent="monitor"; policy_refs (e.g., AC-2, AC-6, AU-2, AU-6, AU-12); classification="C3"; provenance.attestation (SPIFFE/SLSA signing KID)

MCP context (optional) [Informative]

constraints (e.g., "session_recording_required", "realtime_block:true", "notify_owner:on_flag"); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

PEPs/PAM must deny privileged access if recording is missing or unsigned when session_recording_required is active; SOC tooling must verify provenance signatures and honor legal_hold on artifacts/events.

NIST SP 800-160v2 linkage [Informative]

Evaluate & Maintain — assure privileged activity monitoring, integrity, and non-repudiation (see also NIST SP 800-53 Rev.5 AC/AU families).

Automation feasibility [Informative]

High (stream ingestion, baselining, scoring, alerting). Sanctions (kill/lock, account actions) remain HITL-gated.

Output Contracts (merged) [Informative]

OC-1: PrivilegedAnomaly [Informative]

- **Producer(s):** C4
- **Topic/Path:** Kafka/AMQP sec.privileged.anomaly.v1
- **Schema/Format:** JSON/Avro {event_id, session_id, severity, anomaly_score, rule_hits[], commands[], ticket_ref, actor, target, evidence_refs[], legal_hold, fingerprints{sha256_transcript, sha256_window}, rationale_url}
- **Classification:** C3
- **Delivery:** at-least-once
- **Ordering:** per session_id
- **Idempotency-Key:** sha256(session_id, anomaly_ts_floor_1s, anomaly_fingerprint)
- **Ack/Nack:** broker ACK (ISR quorum); NACK → retry/backoff
- **Timeouts/Retry:** publish≤2s; exp-backoff≤7x
- **Side-Effects:** open/annotate case if severity>=high (via OC-3); notify owner if notify_owner:on_flag
- **HITL Token:** none (event only)
- **Observability:** trace_id, mission_id, policy_refs, decision_basis.summary_ref, provenance.attestation
- **Retention/TTL:** 7 years (event + hashes)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=PrivilegedAnomaly@1.0 | json_schema_uri=uri://schema/privileged-anomaly-1.0.json | sha256= | producers=C4 | consumers=SIEM-01, Case-01 | accepts=1.0–1.x

OC-2: SessionSnapshot [Informative]

- **Producer(s):** C4
- **Topic/Path:** Kafka/AMQP sec.privileged.session.snapshot.v1

- **Schema/Format:** JSON/Avro {session_id, window{t0,t1}, rolling_digest, top_commands[], risk_delta, cpu_io_hints, transcript_pointer}
- **Classification:** C3
- **Delivery:** at-least-once
- **Ordering:** per session_id
- **Idempotency-Key:** sha256(session_id, window_t1_floor_5s)
- **Ack/Nack:** broker ACK; retry/backoff
- **Timeouts/Retry:** publish<=2s; exp-backoff<=5x
- **Side-Effects:** updates dashboards; accelerates case triage
- **HITL Token:** none
- **Observability:** trace_id, mission_id, provenance.attestation
- **Retention/TTL:** 1 year

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When snapshotting is enabled for long-running sessions

schema_id=SessionSnapshot@1.0 | json_schema_uri=uri://schema/session-snapshot-1.0.json

OC-3: CaseHandoff [Informative, optional]

- **Producer(s):** C4
- **Topic/Path:** DFIR/Case Mgmt REST/gRPC /cases
- **Schema/Format:** JSON {case_id?, session_id, severity, summary, anomaly_refs[], artifact_refs[], legal_hold, assignments[]}
- **Classification:** C2
- **Delivery:** exactly-once per session_id per anomaly_id (consumer enforces)
- **Ordering:** per case_id
- **Idempotency-Key:** sha256(session_id, anomaly_id)
- **Ack/Nack:** 2xx case_id issued; NACK → retry/backoff
- **Side-Effects:** locks artifacts; notifies on-call

- **HITL Token:** required to attach “sanction requested” actions
- **Observability:** trace_id, mission_id
- **Retention/TTL:** per IR policy (≥ 1 year)

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When DFIR/Case Mgmt integration is present

schema_id=CaseHandoff@1.0 | json_schema_uri=uri://schema/case-handoff-1.0.json

OC-4: SessionArtifactStored [Informative]

- **Producer(s):** C4
- **Topic/Path:** Object storage manifest sec.artifacts.session.v1 (or metadata stream)
- **Schema/Format:** JSON {session_id, artifact_type in [transcript, video, hash_index], uri, sha256, size, signed_by, retention_tag, legal_hold}
- **Classification:** C3
- **Delivery:** at-least-once
- **Ordering:** per session_id
- **Idempotency-Key:** sha256(session_id, uri, sha256)
- **Ack/Nack:** storage 201 Created; NACK → retry/backoff; alert on mismatch
- **Timeouts/Retry:** ack $\leq$ 10s; exp-backoff $\leq$ 5x
- **Side-Effects:** updates evidence lake index; exposes immutable pointer to SIEM/case
- **HITL Token:** none
- **Observability:** trace_id, mission_id, provenance.attestation
- **Retention/TTL:** default 7 years; override when legal_hold=true

Schema Capsule (OC-4) [Normative]

Requirement Level: Required

Condition: Always

schema_id=SessionArtifactStored@1.0 | json_schema_uri=uri://schema/session-artifact-stored-1.0.json

OC-5: RealTimeBlockRequest [Informative]

- **Producer(s):** C4
- **Topic/Path:** PAM/Teleport REST/gRPC /sessions/{id}:terminate or /sessions/{id}:lock
- **Schema/Format:** JSON {session_id, reason, severity, anomaly_refs[], requires_HITL=true, requestor, ttl_s}
- **Classification:** C2
- **Delivery:** exactly-once per session_id (consumer enforces)
- **Ordering:** per session_id
- **Idempotency-Key:** sha256(session_id, reason_hash)
- **Ack/Nack:** 2xx ACK; else retry<=3; escalate to human
- **Side-Effects:** session terminated/locked; audit record appended
- **HITL Token:** required
- **Observability:** trace_id, mission_id
- **Retention/TTL:** 7 years

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When realtime_block:true constraint is active and PAM supports API blocks
schema_id=RealTimeBlockRequest@1.0 | json_schema_uri=uri://schema/realtime-block-request-1.0.json

State machine (concise) [Informative]

states = { idle, awaiting_session_start, recording, streaming_analysis, flagged, snapshotting, handing_off, blocking, legal_hold, rolled_back, failed, closed }
transition(idle -> awaiting_session_start) on PAM session_start
transition(awaiting_session_start -> recording) when recording_ref verified and approvals present
transition(recording -> streaming_analysis) when first command arrives
transition(streaming_analysis -> flagged) when anomaly_score >= theta_flag or rule_hit in {"danger_command", "policy_violation"}
transition(streaming_analysis -> snapshotting) every T seconds for long sessions
transition(flagged -> blocking) when severity >= high and constraint realtime_block:true and HITL token present

transition(flagged -> handing_off) when case created or updated
 transition(* -> legal_hold) when legal_hold=true set (by model or human)
 transition(blocking -> closed) when PAM confirms terminate/lock
 transition(handing_off -> closed) when case triage complete and session ended
 transition(* -> failed) on signature or storage errors

 timeout(streaming_analysis, 2s) -> snapshotting (emit heartbeat)
 idempotency_key = sha256(session_id, anomaly_ts_floor_1s, anomaly_fingerprint) for PrivilegedAnomaly; sha256(session_id, window_t1_floor_5s) for SessionSnapshot

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 PrivilegedAnomaly	Required	Any anomaly detected	SOC triage, alerting, governance
OC-2 SessionSnapshot	Conditionally Required	Snapshotting enabled for long-running sessions	Situational awareness, mid-session triage
OC-3 CaseHandoff	Optional	DFIR/Case integration present	Incident management workflow
OC-4 SessionArtifactStored	Required	Always	Non-repudiation, audit, evidence retention
OC-5 RealTimeBlockRequest	Conditionally Required	realtime_block:true and PAM supports API blocks	Rapid containment (HITL-gated)

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
 - **Conditionally Required:** Must be implemented when trigger condition is met
 - **Optional:** May be implemented for enhanced functionality
-

Policies and HITL gates [Informative]

- `policy_refs`: AC-2, AC-6, AU-2, AU-6, AU-12 (+ local “danger command” lists and escalation windows).
- **HITL required**: `RealTimeBlockRequest`; sanctions (account disable, ticket closure with sanctions); classification downgrades; artifact purges.
- **Automatic HITL escalation triggers**: `model_confidence < theta_low`; `model_drift_detected = true`; `anomaly_score >= theta_block`; multi-host lateral movement detected.

SLOs and KPIs [Informative]

- **DetectionLatency_p95** ≤ 2 s (command $\rightarrow$ PrivilegedAnomaly)
- **ArtifactIngest_p95** ≤ 10 s (recording_ref $\rightarrow$ manifest stored)
- **FalsePositiveRate_30d** ≤ 2 percent
- **MissedHighSeverityRate_30d** ≤ 0.5 percent
- **BlockExecutionAck_p95** ≤ 3 s (when enabled)

Outputs index [Informative]

[OC-1 PrivilegedAnomaly], [OC-2 SessionSnapshot], [OC-3 CaseHandoff], [OC-4 SessionArtifactStored], [OC-5 RealTimeBlockRequest]

Technical Implementation Details (C4) [Informative]

Model and training profile [Informative]

`model_id`=psm-text-model; `temperature`=0.1; `max_tokens_out`=600
`prompt_pack_id`=psm-baseline-v1 (admin baselines, danger commands, SoP windows, ATT&CK tactics)
`RAG`: `sources`={approved sessions index, command catalogs, policy exceptions, parser grammars}; `max_docs`=8; `min_similarity`=0.78; citations required
`fine_tuning/adapters`: none initially; eval on anomaly precision/recall and rationale fidelity
`guardrails`: read-only to recordings; strict topic allowlist; deny writing secrets to logs

Memory and state [Informative]

`working_memory.max_tokens`=4k; `eviction`=recency_then_importance
`episodic_memory`: per `mission_id` journal (session timeline, anomalies, snapshots, artifacts), `ttl`=365d
`semantic_memory`: `namespaces`=["command-catalog", "baselines", "tickets", "hosts"];

embeddings=text-embedding-sec-v1; k=8

durable_state_store: event-sourced journal; periodic snapshots of scoring state

consistency: at-least-once (events/artifacts); exactly-once (CaseHandoff per session_id, anomaly_id)

idempotency: per Output Contracts

Decision and routing logic [Informative]

Let features be:

- f1 = command_rarity in [0,1] (per role and host class)
- f2 = escalation_context in [0,1] (sudo/su/psexec/kinit etc.)
- f3 = offhours_indicator in [0,1] (outside change window)
- f4 = scope_delta in [0,1] (count of principals/hosts touched normalized)
- f5 = policy_mismatch in [0,1] (no ticket/approval/recording)

anomaly_score = 0.35f1 + 0.25f2 + 0.15f3 + 0.15f4 + 0.10*f5

Thresholds:

- if policy_mismatch == 1 then **severity = high** and emit PrivilegedAnomaly
- else if anomaly_score >= 0.75 then severity = high
- else if anomaly_score >= 0.55 then severity = medium
- else severity = low

Block rules (requires constraint and HITL):

- if severity == high and command in danger_list AND lateral_movement_detected == true then request RealTimeBlockRequest

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens, adversarial (obfuscation, chunked exfil), prompt-bait commands]

thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below

red_team_cycle: monthly ATT&CK-inspired drills (TA0003, TA0005, TA0007, TA0010)

rollback_policy: revert prompt_pack_id/model_id on eval_drop >= 1.5 percentage points for 48 h

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what/when/where; top features f1..f5; commands triggering; hashes; evidence_refs; signed rationale URL

UI/API: expose classification_label=C3, provenance.attestation, decision_rationale_url

audit_log_format: JSONL with stable fields; store cryptographic hashes not full content where feasible

Incident Response Integration [Informative]

on severity>=high: emit PrivilegedAnomaly (OC-1), create CaseHandoff (OC-3), pin artifacts (OC-4), optional RealTimeBlockRequest (OC-5) with HITL

Change Impact Assessment [Informative]

simulate new danger_list or threshold changes on replayed recordings; forbid rollout if FalsePositiveRate_7d would exceed policy

Stakeholder Feedback Loop [Informative]

analyst labels (true_positive/false_positive/root_cause) feed governance-reviewed rubric updates; never auto-train on raw recordings

Data Sovereignty and Legal Hold [Informative]

enforce region-scoped buckets; SSE-KMS with key separation; legal_hold=true overrides TTL and purge

Interfaces (links only) [Informative]

Consumes: PAM Telemetry; Keystroke/Command Logs
Produces: OC-1, OC-2, OC-3, OC-4, OC-5 (as enabled)

Safety and abuse prevention [Informative]

kill_switch on signature mismatch or storage integrity error; redact secrets from logs; blast-radius caps on block requests

Testing and validation [Informative]

contract tests from Schema Capsules; offline replay; chaos tests (delayed/duplicated events); drift checks and rollback

Deployment and lifecycle [Informative]

HPA on ingest QPS; backpressure and spill-to-disk; canary for model/rule changes; SBOM + attestations; sign outputs

References / Standards [Informative]

NIST SP 800-160 Vol.2; NIST SP 800-53 Rev.5 (AC-2/6, AU-2/6/12); NIST SP 800-61; NIST SP 800-207 (ZTA); MITRE ATT&CK; CIS Controls v8; SLSA; SPIFFE/SPIRE.

MCP-Native Protocol Specification (C4) [Normative]

- **Native Protocol(s) Consumed:** PAM Telemetry (REST/Webhook/Syslog); Keystroke/Command Logs (NDJSON/REST/gRPC)
- **Native Protocol(s) Produced:** Kafka/AMQP (PrivilegedAnomaly, SessionSnapshot); REST/gRPC CaseHandoff (optional); Object Storage artifacts
- **MCP Context Fields:**
 - **Required:** mission_id; role="PrivilegedSessionMonitorAgent"; intent="monitor"; policy_refs; classification="C3"; provenance.attestation
 - **Optional:** constraints; decision_basis; legal_hold
- **Enforcement Note:** Consumers must validate provenance; PEPs deny privileged access when session_recording_required is unmet; HITL token mandatory for block actions.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** authoritative native + MCP-wrapped PAM and Command events as provided above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

C5. Identity Federation Agent

Agent Blueprint [Informative]

Purpose: Establish and maintain cross-domain SSO trusts (partners, B2B/B2C), validate partner metadata and keys, publish federation configurations and TrustChange events, and manage temporary/conditional trusts.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **SAML 2.0 Metadata (XML)** — entityID, IdP/SP descriptors, bindings, certs (X509), endpoints, NameID formats.
- **OIDC Discovery (RFC 8414 /well-known)** — issuer, endpoints, algorithms, supported scopes/claims, jwks_uri.

- **JWKS (RFC 7517)** — current signing/encryption keys (kid, kty, use, alg, modulus/exponent or crv/x/y).

Model training / knowledge (what the LLM relies on):

- Prompt-pack for federation hygiene: SAML/OIDC hardening checklists, key strength/alg policy (min RSA bits, allowed EC curves), clock/issuer/audience rules, scope minimization, mTLS/PKCE requirements.
- RAG sources: standards excerpts (SAML2, RFC 8414/7517), enterprise federation policy-as-code repo, partner registry (risk tier, geos, DPA status); do **not** train on partner PII—use evidence_refs only.
- Guardrails: cannot enable trusts with algorithms below policy minimum; cannot widen scopes beyond allowed_scopes; writes limited to IdP/gateway config endpoints and event topics; TTL required for temporary trusts.

Decisions it makes (deterministic + model-assisted):

- **Metadata validation:** schema + signature checks (when available), endpoint sanity, HTTPS/mTLS, clock skew tolerance, binding compatibility.
- **Key lifecycle:** accept/rotate/disable based on kid freshness, overlap windows, and algorithm policy; pin kid where supported.
- **Scope & claim control:** approve requested scopes/claims against policy; downgrade to minimum needed; route to **HITL** when scopes exceed baseline.
- **Trust disposition:** publish (enable), update (rotate keys/endpoints), suspend/expire (policy/TTL breach), or disable (risk/high).
- **Eventing:** emit **TrustChange** on established/rotated/expired/disabled; open **PartnerScopeReviewRequest** when exceptions are requested.

Routing / where outputs go:

- **Federation Configs** → IdP / gateways (SAML trust, OIDC client/provider config).
- **Kafka/AMQP** → TrustChange, optional KeyRotationNotice, FederationAnomalyEvent.
- **Tickets/alerts** → partner exceptions, failing discovery/metadata fetch, invalid assertions detected downstream.

Automation scope vs. manual/HITL:

- **Fully automated:** discovery fetch/parse; baseline validation; push configs for compliant partners; routine key overlap/rollover; auto-expire per TTL.

- **HITL required:** unusual scopes/claims; algorithm downgrades; disabling high-revenue partner; cross-region data transfer beyond declared region.
- **Manual outside agent:** partner legal onboarding (DPA/SCC), commercial terms, bespoke attribute transformation design.

Security Domain: Identity, Credential, and Access Management (ICAM)

Inputs (native protocols consumed) [Informative]

1. **SAML 2.0 Metadata (XML)** — IdP/SP descriptors, bindings, certificates.
2. **OIDC Discovery (/well-known, RFC 8414)** — issuer, endpoints, algorithms, scopes/claims.
3. **JWKS (RFC 7517)** — signing/encryption public keys.

Example: Consumed Protocol — SAML 2.0 Metadata [Informative]

Native payload (excerpt)

```
<EntityDescriptor entityID="https://idp.partner.example.com/idp"
xmlns="urn:oasis:names:tc:SAML:2.0:metadata">
```

```
<IDPSSODescriptor
protocolSupportEnumeration="urn:oasis:names:tc:SAML:2.0:protocol">
```

```
<KeyDescriptor use="signing">
```

```
<KeyInfo xmlns="http://www.w3.org/2000/09/xmldsig#">
```

```
<X509Data><X509Certificate>MIIC...AB</X509Certificate></X509Data>
```

```
</KeyInfo>
```

```
</KeyDescriptor>
```

```
<SingleSignOnService Binding="urn:oasis:names:tc:SAML:2.0:bindings:HTTP-
Redirect"
```

```
Location="https://idp.partner.example.com/idp/profile/SAML2/Redirect/SSO"/>
```

```
<NameIDFormat>urn:oasis:names:tc:SAML:1.1:nameid-
format:emailAddress</NameIDFormat>
```

```
</IDPSSODescriptor>
```

```
</EntityDescriptor>
```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-c5-saml-1111-2222-3333-4444",
    "thread_id": "uuid-saml-idp-partner-acme",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "IdentityFederationAgent",
    "intent": "federate",
    "policy_refs": ["IA-2", "IA-8", "SC-12", "SC-13"],
    "constraints": ["partner_id:acme", "region:us,eu", "trust_ttl_hours:72"],
    "decision_basis": {
      "evidence_refs":
["uri://saml/metadata/idp/https%3A%2F%2Fidp.partner.example.com%2Fidp"],
      "confidence": 0.97,
      "explanation_ref": "uri://kb/federation/saml-metadata-validation"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/icam/identity-federation-agent",
      "signing_kid": "kid-saml-c5-01",
      "attestation_ref": "uri://slsa/attestations/identity-federation@sha256:saml01"
    },
    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": "<EntityDescriptor ...>...</EntityDescriptor>"
}

```

Example: Consumed Protocol — OIDC Discovery [Informative]

Native payload

```
{
  "issuer": "https://accounts.partner.example.com",
  "authorization_endpoint": "https://accounts.partner.example.com/oauth2/v1/authorize",
  "token_endpoint": "https://accounts.partner.example.com/oauth2/v1/token",
  "jwks_uri": "https://accounts.partner.example.com/oauth2/v1/keys",
  "userinfo_endpoint": "https://accounts.partner.example.com/oauth2/v1/userinfo",
  "response_types_supported": ["code", "id_token", "code id_token"],
  "id_token_signing_alg_values_supported": ["RS256", "ES256"],
  "scopes_supported": ["openid", "email", "profile"],
  "claims_supported": ["sub", "email", "email_verified", "name"]
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-c5-oidc-5555-6666-7777-8888",
    "thread_id": "uuid-oidc-accounts.partner.example.com",
    "task_id": "uuid-9911-8822-7733-6644",
    "role": "IdentityFederationAgent",
    "intent": "federate",
    "policy_refs": ["IA-2", "IA-8", "SC-12", "SC-13"],
    "constraints": ["partner_id:acme", "allowed_scopes:['openid','email','profile']",
    "trust_ttl_hours:72"],
    "decision_basis": {
      "evidence_refs": ["https://accounts.partner.example.com/.well-known/openid-configuration"],
      "confidence": 0.95,
      "explanation_ref": "uri://kb/federation/oidc-discovery-validation"
    }
  }
}
```

```

    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/icam/identity-federation-agent",
      "signing_kid": "kid-oidc-c5-02",
      "attestation_ref": "uri://slsa/attestations/identity-federation@sha256:oidc02"
    },
    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": { "...": "as above" }
}

```

Example: Consumed Protocol — JWKS [Informative]

Native payload

```

{
  "keys": [
    { "kty": "RSA", "kid": "acme-rs256-2025-08", "use": "sig", "alg": "RS256", "n":
"sH5r8c...Q", "e": "AQAB" }
  ]
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-c5-jwks-aaaa-bbbb-cccc-dddd",
    "thread_id": "uuid-jwks-acme-rs256-2025-08",
    "task_id": "uuid-1122-3344-5566-7788",
    "role": "IdentityFederationAgent",
    "intent": "federate",

```

```

"policy_refs": ["SC-12", "SC-13"],
"constraints": ["partner_id:acme", "trust_ttl_hours:72"],
"decision_basis": {
  "evidence_refs": ["https://accounts.partner.example.com/oauth2/v1/keys"],
  "confidence": 0.99,
  "explanation_ref": "uri://kb/federation/key-rollover-and-kid-pinning"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/icam/identity-federation-agent",
  "signing_kid": "kid-jwks-c5-03",
  "attestation_ref": "uri://slsa/attestations/identity-federation@sha256:jwks03"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "as above" }
}

```

Outputs (native) [Informative]

- **Federation Configs** to IdP/gateways (SAML trust, OIDC client/provider).
- **TrustChange** events (Kafka/AMQP) for established/rotated/expired/disabled states.

MCP context (required) [Informative]

mission_id; role="IdentityFederationAgent"; intent="federate"; policy_refs=["IA-2", "IA-8", "SC-12", "SC-13"]; provenance.attestation (SPIFFE/SLSA + KID)

MCP context (optional) [Informative]

constraints (e.g., "region:us,eu", "partner_id:acme", "trust_ttl_hours:72", "allowed_scopes:['openid','email','profile']"); classification (default C2); decision_basis; legal_hold

Enforcement note [Informative]

IdP/PEP MUST pin issuer/audience, enforce kid and algorithm policy, restrict scopes/claims to allowed set, and honor trust_ttl_hours for auto-expiry. Config updates must be signed and attributable via provenance.attestation.

NIST SP 800-160v2 linkage [Informative]

Implement/Maintain — resilient external trust establishment and key lifecycle; supports 800-53 Rev.5 IA-2/IA-8, SC-12/SC-13.

Automation feasibility [Informative]

High (metadata validation, discovery fetch, key rollover, config push; HITL for exceptional partner risk or unusual scopes).

Output Contracts (merged) [Informative]

OC-1: FederationConfigPublish [Informative]

- **Producer(s):** C5
- **Topic/Path:** IdP/gateway config API (e.g., /federation/trusts, /oidc/clients) or oci://federation-registry/<org>/<trust>:<ver>
- **Schema/Format:** JSON or XML (provider-specific), including issuer/entityID, endpoints, bindings, kid set with overlap window, scopes/claims, TTL, signatures
- **Classification:** C1–C2 (minimized partner data)
- **Delivery:** at-least-once
- **Ordering:** per trust_id
- **Idempotency-Key:** sha256(trust_id, version)
- **Ack/Nack:** 2xx or provider ACK; NACK on schema/policy/compat failure
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; rollback on failed smoke tests
- **Side-Effects:** update registry index; notify relying parties; schedule key refresh
- **HITL Token:** required when scopes exceed baseline or algorithm is downgraded
- **Observability:** trace_id, mission_id, policy_refs, provenance.attestation, decision_basis.summary_ref
- **Retention/TTL:** 7 years (config manifests + signatures)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=FederationConfigPublish@1.0 | json_schema_uri=uri://schema/federation-config-publish-1.0.json | sha256= | producers=C5 | consumers=IdP-GW-01 | accepts=1.0–1.x

OC-2: TrustChange (established/rotated/expired/disabled) [Informative]

- **Producer(s):** C5
- **Topic/Path:** Kafka/AMQP icam.federation.change.v1
- **Schema/Format:** JSON/Avro {trust_id, partner_id, change_type, reason, previous_state, new_state, effective_at, ttl, keys[], scopes[], evidence_refs[]}
- **Classification:** C1
- **Delivery:** at-least-once
- **Ordering:** per trust_id
- **Idempotency-Key:** sha256(trust_id, change_type, effective_at_floor_1s)
- **Ack/Nack:** broker ACK; retry/backoff
- **Side-Effects:** trigger cache purge and JWKS refetch in consumers
- **HITL Token:** none
- **Observability:** trace_id, mission_id, provenance.attestation
- **Retention/TTL:** 3 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When a trust changes state (establish/rotate/expire/disable)

schema_id=TrustChange@1.0 | json_schema_uri=uri://schema/trust-change-1.0.json | producers=C5 | consumers=SIEM-01, IdP-GW-01 | accepts=1.0–1.x

OC-3: TrustRiskAssessment [Informative, optional]

- **Producer(s):** C5
- **Topic/Path:** icam.federation.risk.v1
- **Schema/Format:** JSON {trust_id, risk_score, alg_policy_ok, endpoint_health, scope_deviation, geo_ok, dpa_status, recommended_action}
- **Classification:** C1

- **Delivery/Ordering:** at-least-once; per trust_id
- **Idempotency-Key:** sha256(trust_id, assessment_ts_floor_1h)
- **Ack/Nack:** report_id issued; retry/backoff
- **Side-Effects:** gate promotion to production; open exception workflow if high risk
- **HITL Token:** required to proceed when risk >= high

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When risk-based gating is enabled

schema_id=TrustRiskAssessment@1.0 | json_schema_uri=uri://schema/trust-risk-assessment-1.0.json

OC-4: KeyRotationNotice [Informative]

- **Producer(s):** C5
- **Topic/Path:** icam.federation.key.rotation.v1
- **Schema/Format:** JSON {trust_id, old_kids[], new_kids[], overlap_window_s, cutover_at, alg, key_strength_bits}
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per trust_id
- **Idempotency-Key:** sha256(trust_id, cutover_at_floor_1s)
- **Ack/Nack:** broker ACK; retry/backoff
- **Side-Effects:** signal caches to prefetch new JWKS; verify signature overlap
- **HITL Token:** none (notice)
- **Retention/TTL:** 3 years

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When partner keys rotate (detected via JWKS/metadata)

schema_id=KeyRotationNotice@1.0 | json_schema_uri=uri://schema/key-rotation-notice-1.0.json

OC-5: FederationAnomalyEvent [Informative, optional]

- **Producer(s):** C5

- **Topic/Path:** icam.federation.anomaly.v1
- **Schema/Format:** JSON {trust_id, anomaly_type in [issuer_mismatch, alg_downgrade, aud_mismatch, clock_skew], severity, details, evidence_refs[]}
- **Classification:** C1
- **Delivery/Ordering:** at-least-once
- **Idempotency-Key:** sha256(trust_id, anomaly_type, observed_at_floor_1s)
- **HITL Token:** none

Schema Capsule (OC-5) [Normative]

Requirement Level: Optional

Condition: When SIEM/IR integration is present

schema_id=FederationAnomalyEvent@1.0 | json_schema_uri=uri://schema/federation-anomaly-1.0.json

State machine (concise) [Informative]

states = { idle, fetching_metadata, validating, publishing_config, key_overlap, monitoring, rotating, suspended, expired, contested, failed, closed }

transition(idle -> fetching_metadata) on discovery/metadata/JWKS fetch

transition(fetching_metadata -> validating) when payload retrieved

transition(validating -> publishing_config) when checks pass and scopes within policy

transition(validating -> contested) when scopes/alg/region exceed policy (HITL)

transition(publishing_config -> key_overlap) when new keys staged

transition(key_overlap -> rotating) at cutover_at when overlap satisfied

transition(rotating -> monitoring) after successful validation

transition(monitoring -> suspended) on endpoint failure, issuer/aud mismatch, or anomaly

transition(monitoring -> expired) when TTL reached

transition(* -> failed) on signature or schema error

timeout(validating, 60s) -> failed; retry<=3

idempotency_key = sha256(trust_id, version) for FederationConfigPublish;

sha256(trust_id, change_type, effective_at_floor_1s) for TrustChange

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 FederationConfigPublish	Required	Always	Establish/maintain working federation
OC-2 TrustChange	Conditionally Required	Trust state changes (establish/rotate/expire/disable)	Downstream cache & control synchronization
OC-3 TrustRiskAssessment	Optional	Risk-based gating enabled	Governance & exception review
OC-4 KeyRotationNotice	Conditionally Required	Partner key rotation detected	Safe, coordinated key cutover
OC-5 FederationAnomalyEvent	Optional	SIEM/IR integration present	Incident readiness & detection

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: IA-2, IA-8, SC-12, SC-13 (+ internal federation policy).
- **HITL required:** scope expansion beyond baseline; algorithm downgrade; disabling high-tier partner; cross-region transfer contrary to region constraint.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; anomaly_type in {issuer_mismatch, aud_mismatch, alg_downgrade}.

SLOs and KPIs [Informative]

- ConfigPublishAck_p95 <= 60 s
- MetadataRefresh_MTTR <= 15 min

- **KeyRotationCutover_p95** <= 5 min overlap window
- **InvalidAssertionRate_30d** <= 0.1 percent
- **TrustDrift_MTTD** <= 10 min

Outputs index [Informative]

[OC-1 FederationConfigPublish], [OC-2 TrustChange], [OC-3 TrustRiskAssessment], [OC-4 KeyRotationNotice], [OC-5 FederationAnomalyEvent]

Technical Implementation Details (C5) [Informative]

Model and training profile [Informative]

model_id=federation-text-model; temperature=0.1; max_tokens_out=600
 prompt_pack_id=fed-hardening-v1 (SAML/OIDC/JWKS validation, scope minimization, key policy)

RAG: sources={enterprise federation policy, partner registry, standards excerpts, prior configs}; max_docs=8; min_similarity=0.78; citations required

fine_tuning/adapters: none initially; eval gates on validation accuracy and false-negative anomaly rate

guardrails: deny publish on policy violations; enforce TTL for temporary trusts; limit writes to approved IdP/gateway endpoints

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal (fetches, validations, publishes, rotations), ttl=365d

semantic_memory: namespaces=["partners","jwks","metadata","policies"];

embeddings=text-embedding-sec-v1; k=8

durable_state_store: event-sourced; snapshot on each trust version

consistency: at-least-once (events); exactly-once (config publish per trust_id, version)

idempotency: per Output Contracts

Decision and routing logic [Informative]

Let normalized features be:

- f_alg in [0,1] (1 = meets/ exceeds algorithm policy)
- f_key_fresh in [0,1] (age & overlap health)
- f_endpoint in [0,1] (TLS/mTLS, redirect safety, issuer/endpoint coherence)
- f_scope in [0,1] (1 = within allowed_scopes)

- f_{geo} in $[0,1]$ (region match to constraints)

$trust_score = 0.3f_{alg} + 0.25f_{key_fresh} + 0.2f_{endpoint} + 0.15f_{scope} + 0.1f_{geo}$

Decision thresholds:

- if $f_{alg} < 0.6$ or $f_{endpoint} < 0.6 \rightarrow$ reject (contested/HITL).
- else if $trust_score \geq 0.8 \rightarrow$ publish/rotate.
- else $\rightarrow$ publish to staging and emit TrustRiskAssessment.

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[metadata goldens, malformed endpoints, key edge-cases]

thresholds: eval_pass_rate $\geq$ 99.5 percent $\rightarrow$ auto_HITL if below

red_team_cycle: monthly federation-bypass drills (issuer/aud spoof, alg confusion, stale key)

rollback_policy: revert last good config on anomaly spike or invalid assertion surge

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: partner_id, checks passed/failed, scopes, keys(kid/alg), TTL, evidence_refs, signed hashes

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL; store digests of metadata/JWKS and config manifests

Incident Response Integration [Informative]

emit FederationAnomalyEvent on issuer/aud mismatch or alg downgrade; open case and suspend trust if severity high

Change Impact Assessment [Informative]

simulate config against shadow gateway; check assertion success/error deltas; block rollout on regression thresholds

Stakeholder Feedback Loop [Informative]

collect partner/team feedback on denied scopes; after governance review, update baseline policy; never auto-train on partner data

Data Sovereignty and Legal Hold [Informative]

apply region constraints at ingress/egress; set legal_hold=true for contested trusts; TTL overrides paused during legal hold

Interfaces (links only) [Informative]

Consumes: SAML 2.0 Metadata; OIDC Discovery; JWKS
Produces: OC-1, OC-2, OC-3, OC-4, OC-5 (as enabled)

Safety and abuse prevention [Informative]

kill_switch on issuer/audience mismatch; alg confusion prevention; strict scope allowlist; rate-limit config pushes; sign all outputs

Testing and validation [Informative]

contract tests from Schema Capsules; offline replay with recorded metadata/JWKS; chaos tests (endpoint flaps); drift checks & rollback

Deployment and lifecycle [Informative]

HPA on partner count/refresh cadence; canary configs; SBOM + SLSA attestations; sign/pin everything; scheduled key overlap windows

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (IA-2, IA-8, SC-12, SC-13); NIST SP 800-207 (ZTA); SAML 2.0; RFC 8414 (OIDC Discovery); RFC 7517 (JWKS); FAPI/PKCE best practices; CIS Controls v8.

MCP-Native Protocol Specification (C5) [Normative]

- **Native Protocol(s) Consumed:** SAML 2.0 Metadata (XML); OIDC Discovery (/.well-known JSON, RFC 8414); JWKS (RFC 7517 JSON)
- **Native Protocol(s) Produced:** Federation Configs to IdP/gateways; Kafka/AMQP TrustChange
- **MCP Context Fields:**
 - **Required:** mission_id; role="IdentityFederationAgent"; intent="federate"; policy_refs=["IA-2","IA-8","SC-12","SC-13"]; provenance.attestation
 - **Optional:** constraints (region, partner_id, trust_ttl_hours, allowed_scopes); classification (typically C2); decision_basis; legal_hold
- **Enforcement Note:** Consumers must verify provenance; IdP/gateways must reject unsigned or policy-noncompliant configs and enforce kid pinning, issuer/audience binding, scope limits, and TTL expiries.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.

- **Example payloads:** authoritative native + MCP-wrapped SAML/OIDC/JWKS examples above.
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

C6. Access Audit Agent

Agent Blueprint [Informative]

Purpose: Drive periodic access certifications and detect Separation-of-Duties (SoD) violations by reconciling the entitlement graph with actual usage; produce `AccessReview` tasks and `RevokeRecommendation` items.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Entitlement Graph (REST/GraphQL)** — identities, groups, roles, resource permissions, SoD policies and lineage (who granted, via what).
- **Access/Usage Logs (REST/JSON or Syslog/OTel)** — sign-in and app/resource activity with last-used timestamps; MFA challenge counts.

Model training / knowledge (what the LLM relies on):

- Prompt-pack for least-privilege heuristics, certification campaign patterns, SoD catalogs, attestation wording, and revocation playbooks.
- RAG sources: entitlement graph snapshots, SoD policy registry, historical certification outcomes, exception lists; do **not** train on raw PII—use `evidence_refs` and store hashes only.
- Guardrails: write scopes limited to review task queues, IGA/IdP campaign APIs, and Kafka topics; bulk revocations require configured co-signers (manager, `app_owner`) per constraints.

Decisions it makes (deterministic + model-assisted):

- **In-scope selection:** pick identities/resources for review by policy (e.g., privileged roles, stale usage, contractor populations).
- **SoD detection:** evaluate role/entitlement combinations against SoD policies; assign severity and recommended action.

- **Revocation proposals:** generate **RevokeRecommendation** for unused or out-of-policy access with rationale and evidence; gate bulk actions behind co-sign.
- **Campaign orchestration:** create or update certification campaigns in IGA, partition reviewers, and track completion; re-issue reminders.
- **Exception routing:** open appeal/exception task when reviewer contests a recommendation.

Routing / where outputs go:

- **Kafka/AMQP** → AccessReview, RevokeRecommendation, SoDViolation.
- **REST/gRPC** → IGA/IdP campaign APIs for review creation and certification outcomes.
- **Tickets/alerts** → queue to managers/app owners for co-sign; SIEM notification on critical SoD.

Automation scope vs. manual/HITL:

- **Fully automated:** data collection, correlation, candidate selection, task issuance, reminder cadence, evidence linking.
- **HITL required:** approve bulk revoke operations; override SoD blocks; certify privileged exceptions.
- **Manual outside agent:** SoD policy authoring; enterprise attestation cadence policy; exception policy sign-off.

Security Domain: Identity, Credential, and Access Management (ICAM)

Inputs (native protocols consumed) [Informative]

1. **Entitlement Graph (REST/GraphQL)** — graph snapshot: identities, memberships, entitlements, SoD policies.
2. **Access/Usage Logs (REST/JSON or Syslog/OTel Logs)** — last-used/activity summaries.

Example: Consumed Protocol — Entitlement Graph (slice) [Informative]

Native payload

```
{
  "snapshot_id": "entgraph-2025-08-15T13:00:00Z",
  "identities": [
```

```

    {"employee_id": "E102993", "email": "april.ng@example.com",
"manager_employee_id": "E100014"}
],
"memberships": [
    {"employee_id": "E102993", "group": "eng-swe-l1"},
    {"employee_id": "E102993", "role": "FIN_AP_APPROVER"}
],
"entitlements": [
    {
        "resource": "erp.ap.invoices",
        "actions": ["view","approve","export"],
        "assigned_via": "role:FIN_AP_APPROVER",
        "conditions": [{"attribute": "amount_usd", "op": "<=", "value": 50000}]
    }
],
"sod_policies": [
    {"policy_id": "SOD-AP-01", "conflicts":
["FIN_AP_REQUESTOR","FIN_AP_APPROVER"]}
]
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-c6-ent-1111-2222-3333-4444",
    "thread_id": "uuid-entgraph-entgraph-2025-08-15T13:00:00Z",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "AccessAuditAgent",

```

```

"intent": "audit",
"policy_refs": ["AC-2","AC-5","AC-6"],
"constraints": ["bulk_revoke_requires_cosign:manager,app_owner"],
"decision_basis": {
  "evidence_refs": ["uri://entitlements/snapshots/entgraph-2025-08-15T13:00:00Z"],
  "confidence": 0.97,
  "explanation_ref": "uri://kb/icam/access-review/graph-correlation"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/icam/access-audit-agent",
  "signing_kid": "kid-ent-c6-01",
  "attestation_ref": "uri://slsa/attestations/access-audit@sha256:ent01"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "as above" }
}

```

Example: Consumed Protocol — Access/Usage Logs (last-used) [Informative]
Native payload

```

{
  "employee_id": "E102993",
  "resource": "erp.ap.invoices",
  "action_counts_30d": {"view": 14, "approve": 0, "export": 0},
  "last_used": "2025-07-12T18:25:00Z",
  "source": "erp.auditlog",
  "signins_30d": 5,
  "mfa_challenges": 5
}

```

```

}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-c6-usage-5555-6666-7777-8888",
    "thread_id": "uuid-usage-E102993-erp.ap.invoices",
    "task_id": "uuid-9911-8822-7733-6644",
    "role": "AccessAuditAgent",
    "intent": "audit",
    "policy_refs": ["AC-2", "AC-6", "AU-6"],
    "constraints": ["bulk_revoke_requires_cosign:manager,app_owner"],
    "decision_basis": {
      "evidence_refs": ["uri://erp/auditlog/E102993/erp.ap.invoices/last-30d"],
      "confidence": 0.94,
      "explanation_ref": "uri://kb/icam/certification/last-used-policy"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/icam/access-audit-agent",
      "signing_kid": "kid-usage-c6-02",
      "attestation_ref": "uri://slsa/attestations/access-audit@sha256:usage02"
    },
    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": { "...": "as above" }
}

```

Outputs (native) [Informative]

- **Kafka/AMQP:** AccessReview, RevokeRecommendation, SoDViolation.
- **REST/gRPC:** IGA/IdP review campaign create/update and certification outcomes.

MCP context (required) [Informative]

mission_id; role="AccessAuditAgent"; intent="audit"; policy_refs=["AC-2","AC-5","AC-6","AU-6"]; constraints as configured; provenance.attestation (SPIFFE/SLSA + KID)

MCP context (optional) [Informative]

classification (default C2; elevate to C3 for privileged identities); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

IGA/IdP and downstream revocation handlers **MUST** verify provenance; **bulk** revoke actions **MUST** present co-sign tokens from manager and app_owner when bulk_revoke_requires_csign:* is active.

NIST SP 800-160v2 linkage [Informative]

Evaluate & Maintain — continuously validate least-privilege and SoD alignment; ties to NIST SP 800-53 Rev. 5 AC-2/5/6 and AU-6.

Automation feasibility [Informative]

High (collection, correlation, scoring, and tasking are automatable; sanctions and high-risk exceptions stay HITL-gated).

Output Contracts (merged) [Informative]

OC-1: AccessReview [Informative]

- **Producer(s):** C6
- **Topic/Path:** Kafka/AMQP icam.access.review.v1
- **Schema/Format:** JSON/Avro {review_id, employee_id, reviewer_id, items[], due_at, severity, rationale, evidence_refs[], campaign_id?, privileges[], last_used, attest_options["keep","revoke","exception"], appeal_url?}
- **Classification:** C2 (C3 if privileged)
- **Delivery:** at-least-once
- **Ordering:** per campaign_id

- **Idempotency-Key:** sha256(review_id)
- **Ack/Nack:** broker ACK; retry/backoff
- **Timeouts/Retry:** publish<=5s; exp-backoff<=5x
- **Side-Effects:** creates or links IGA review task; starts reminder cadence
- **HITL Token:** none (task only)
- **Observability:** trace_id, mission_id, policy_refs, decision_basis.summary_ref, provenance.attestation
- **Retention/TTL:** 7 years (audit)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=AccessReview@1.0 | json_schema_uri=uri://schema/access-review-1.0.json | sha256= | producers=C6 | consumers=IGA-01, Reviewer-UI-01 | accepts=1.0–1.x

OC-2: RevokeRecommendation [Informative]

- **Producer(s):** C6
- **Topic/Path:** Kafka/AMQP icam.access.revoke.recommendation.v1
- **Schema/Format:** JSON/Avro {recommendation_id, employee_id, privileges[], reason_code in [unused_90d, sod_conflict, orphaned], last_used, severity, required_cosigners["manager","app_owner"], evidence_refs[], bulk_batch_id?}
- **Classification:** C2 (C3 if privileged)
- **Delivery:** at-least-once
- **Ordering:** per employee_id
- **Idempotency-Key:** sha256(recommendation_id)
- **Ack/Nack:** broker ACK; retry/backoff; open co-sign tasks
- **Timeouts/Retry:** publish<=5s; exp-backoff<=5x
- **Side-Effects:** blocks auto-revoke until co-sign satisfied
- **HITL Token:** required for bulk execution
- **Observability:** trace_id, mission_id, decision_basis.confidence, provenance.attestation

- **Retention/TTL:** 7 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When auto-revoke proposals are enabled

schema_id=RevokeRecommendation@1.0 | json_schema_uri=uri://schema/revoke-recommendation-1.0.json

OC-3: SoDViolation [Informative]

- **Producer(s):** C6
- **Topic/Path:** Kafka/AMQP icam.sod.violation.v1
- **Schema/Format:** JSON/Avro {violation_id, employee_id, conflicts["roleA","roleB"], policy_id, severity, suggested_remediation, evidence_refs[], case_id?}
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per employee_id
- **Idempotency-Key:** sha256(employee_id, policy_id, conflicts_hash)
- **Ack/Nack:** broker ACK; retry/backoff
- **Side-Effects:** opens case or routes to campaign as priority item
- **HITL Token:** required to approve exception
- **Retention/TTL:** 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Required

Condition: Always

schema_id=SoDViolation@1.0 | json_schema_uri=uri://schema/sod-violation-1.0.json

OC-4: CertificationCampaignPublish [Informative]

- **Producer(s):** C6
- **Topic/Path:** IGA/IdP REST/gRPC /campaigns
- **Schema/Format:** JSON {campaign_id, scope_query, start_at, due_at, reviewers[], sla_days, reminder_policy, items_count, signoff_policy}
- **Classification:** C1

- **Delivery:** exactly-once per campaign_id (consumer enforces)
- **Ordering:** per campaign_id
- **Idempotency-Key:** sha256(campaign_id, start_at_floor_1s)
- **Ack/Nack:** 2xx/ACK → campaign created; NACK → retry/backoff
- **Side-Effects:** starts attestation cadence; binds AccessReview items
- **HITL Token:** none
- **Retention/TTL:** 3 years

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When agent manages campaigns via IGA API

schema_id=CertificationCampaignPublish@1.0 |

json_schema_uri=uri://schema/certification-campaign-publish-1.0.json

OC-5: AccessReviewAppeal (contestability) [Informative, optional]

- **Producer(s):** Reviewer-UI-01, C6 (aggregation)
- **Topic/Path:** icam.access.review.appeal.v1
- **Schema/Format:** JSON {review_id, employee_id, item_id, appeal_reason, attachments[], requested_outcome}
- **Classification:** C2
- **Idempotency-Key:** sha256(review_id, item_id)
- **HITL Token:** required for privileged exceptions

Schema Capsule (OC-5) [Normative]

Requirement Level: Optional

Condition: When contestation workflow is enabled

schema_id=AccessReviewAppeal@1.0 | json_schema_uri=uri://schema/access-review-appeal-1.0.json

State machine (concise) [Informative]

states = { idle, ingesting_graph, ingesting_usage, reconciling, generating_reviews, proposing_revokes, campaigning, awaiting_cosign, publishing, monitoring, contested, failed, closed }

transition(idle -> ingesting_graph) on new graph snapshot

transition(ingesting_graph -> ingesting_usage) when snapshot validated
 transition(ingesting_usage -> reconciling) when usage joined
 transition(reconciling -> generating_reviews) when in-scope set computed
 transition(generating_reviews -> proposing_revokes) when stale/SoD candidates found
 transition(proposing_revokes -> awaiting_cosign) when bulk batch prepared and constraints require co-sign
 transition(* -> campaigning) when CertificationCampaignPublish accepted
 transition(* -> contested) on AccessReviewAppeal
 transition(* -> publishing) when events emitted and tasks created
 transition(publishing -> monitoring) until campaign closes
 transition(* -> failed) on schema/signature errors or API NACKs

 timeout(awaiting_cosign, 3d) -> campaigning (mark items as “exception pending”)
 idempotency_key = sha256(review_id) for AccessReview; sha256(recommendation_id) for RevokeRecommendation; sha256(employee_id, policy_id, conflicts_hash) for SoDViolation

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 AccessReview	Required	Always	Launches review and attestation workflow
OC-2 RevokeRecommendation	Conditionally Required	Auto-revoke proposals enabled	Drives least-privilege enforcement
OC-3 SoDViolation	Required	Any SoD conflict detected	Prevents fraud/process risk
OC-4 CertificationCampaignPublish	Conditionally Required	Agent manages campaigns via IGA API	Orchestrates attestations at scale
OC-5 AccessReviewAppeal	Optional	Contestation workflow enabled	Fairness, auditability of exceptions

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- `policy_refs`: AC-2, AC-5, AC-6, AU-6 (+ internal SoD catalog).
- **HITL required:** bulk revocations; privileged exceptions; SoD overrides; campaign closure under target completion < threshold.
- **Automatic HITL escalation triggers:** `model_confidence < theta_low`; `model_drift_detected = true`; SoD severity `>= high`; `revoke_batch_size > limit`.

SLOs and KPIs [Informative]

- **ReviewIssueLatency_p95 <= 10 min** (snapshot → AccessReview)
- **CoverageRate_campaign >= 98 percent** (in-scope items surfaced)
- **FalseRevokeRate_30d <= 1 percent**
- **CoSignCompletion_p95 <= 2 business days** (bulk batches)
- **SoDRemediation_p95 <= 5 business days**

Outputs index [Informative]

[OC-1 AccessReview], [OC-2 RevokeRecommendation], [OC-3 SoDViolation], [OC-4 CertificationCampaignPublish], [OC-5 AccessReviewAppeal]

Technical Implementation Details (C6) [Informative]

Model and training profile [Informative]

`model_id=access-audit-text-model`; `temperature=0.1`; `max_tokens_out=700`
`prompt_pack_id=access-audit-v1` (least-privilege, SoD patterns, attestation language)
 RAG: `sources={entitlement graph snapshots, SoD policy registry, prior review outcomes, exception lists}`; `max_docs=8`; `min_similarity=0.78`; citations required
`fine_tuning/adapters: none initially`; eval gates on recommendation precision/recall and SoD detection accuracy
 guardrails: enforce co-sign policy for bulk revokes; deny writes outside approved topics/APIs

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal (snapshots used, campaigns, decisions),
ttl=365d
semantic_memory:
namespaces=["entitlements","usage","sod","exceptions","campaigns"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced; snapshot per campaign and per batch
consistency: at-least-once (events); exactly-once (campaign create by campaign_id)
idempotency: per Output Contracts

Decision and routing logic [Informative]

Let features be:

- f_{unused} in $[0,1] = \min(1, \text{days_since_last_used} / 90)$
- $f_{\text{privileged}}$ in $[0,1] = 1$ if role in privileged_set else 0
- f_{sod} in $[0,1] = 1$ if SoD conflict exists else 0
- f_{orphaned} in $[0,1] = 1$ if no active manager or app_owner else 0
- $f_{\text{activity_delta}}$ in $[0,1] = \text{normalized drop vs 90d baseline}$

revoke_risk = $0.45f_{\text{unused}} + 0.25f_{\text{privileged}} + 0.20f_{\text{sod}} + 0.10f_{\text{orphaned}}$

Decision thresholds:

- if $f_{\text{sod}} == 1$ then emit **SoDViolation** (severity = high).
- else if $\text{revoke_risk} \geq 0.7$ then emit **RevokeRecommendation** (severity = medium/high).
- else include in **AccessReview** only.

Bulk gating: execute batch if $\text{sum}(\text{privileges_at_risk}) \geq \text{batch_min}$ and all co-signers provided.

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens, adversarial exceptions, synthetic graph joins]

thresholds: eval_pass_rate ≥ 99.5 percent $\rightarrow$ auto_HITL if below

red_team_cycle: monthly SoD-bypass and usage-spoof drills

rollback_policy: revert prompt_pack/model on $\text{FalseRevokeRate}_{7d} > 2$ percent

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what access, last_used, SoD basis, evidence_refs, hashes, reviewer choices; signed rationale URL

UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL; retain digests and pointers, not raw logs

Incident Response Integration [Informative]

emit SoDViolation to SIEM; auto-open case for high-severity; correlate with financial systems where relevant

Change Impact Assessment [Informative]

simulate policy threshold changes on historical data; block rollout if projected
FalseRevokeRate_30d exceeds limit

Stakeholder Feedback Loop [Informative]

ingest reviewer decisions and appeals; update rubric/prompt_pack after governance review; never auto-train on raw PII

Data Sovereignty and Legal Hold [Informative]

regionalize processing; elevate classification to C3 for privileged identities;
legal_hold=true pauses TTL expiry

Interfaces (links only) [Informative]

Consumes: Entitlement Graph; Access/Usage Logs
Produces: OC-1, OC-2, OC-3, OC-4, OC-5 (as enabled)

Safety and abuse prevention [Informative]

kill_switch on signature/schema failures; rate-limit task creation; cap batch sizes;
prevent silent auto-revokes without co-sign

Testing and validation [Informative]

contract tests from Schema Capsules; offline replay of campaigns; chaos tests for
delayed/duplicated logs; drift checks and rollback

Deployment and lifecycle [Informative]

HPA on graph join QPS; backpressure and incremental joins; canary policy changes;
SBOM + SLSA attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (AC-2/5/6, AU-6); NIST SP 800-207 (ZTA); ISO/IEC 27001/27002; CIS Controls v8; MITRE D3FEND.

MCP-Native Protocol Specification (C6) [Normative]

- **Native Protocol(s) Consumed:** Entitlement Graph (REST/GraphQL); Access/Usage Logs (REST/JSON or Syslog/OTel)
- **Native Protocol(s) Produced:** Kafka/AMQP (AccessReview, RevokeRecommendation, SoDViolation); REST/gRPC to IGA/IdP for campaign ops
- **MCP Context Fields:**
 - **Required:** mission_id; role="AccessAuditAgent"; intent="audit"; policy_refs=["AC-2","AC-5","AC-6","AU-6"]; constraints (co-sign policy); provenance.attestation
 - **Optional:** classification (C2 default; C3 if privileged); decision_basis; legal_hold
- **Enforcement Note:** Consumers MUST validate provenance; bulk revocations MUST present required co-sign tokens; SoD exceptions require explicit HITL approval.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL.
- **Example payloads:** authoritative native + MCP-wrapped Entitlement Graph and Usage examples above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is [Normative] and, together with each **Schema Capsule**, defines testable requirements.

C7. Crypto Key Manager Agent

Agent Blueprint [Informative]

Purpose: Manage key and certificate lifecycle: issuance (CSR enrollment), rotation (scheduled/conditional), escrow/backup (where policy allows), and revocation (CRL/OCSP).

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **CSR Requests — PKCS#10/ACME:** subject/CN, SANs, key parameters, proof-of-possession (for ACME), requested profile.

- **Expiry Events — Inventory/Telemetry:** not_before, not_after, days_remaining, deployment_refs.
- **KMS State — Cloud/on-prem KMS/HSM:** key_id, algorithm, version set, rotation policy, attestation/quote, health.

Model training / knowledge (what the LLM relies on):

- Prompt pack for PKI/KMS policies (NIST 800-57, 800-52r2, 800-131A), key/alg profiles (min strength, curves, sig algs), CRL/OCSP best practices, ACME flows.
- RAG sources: CA policy-as-code repo (profiles, name constraints), certificate inventory index, deployment registry (where certs live), HSM/KMS attestation docs; do **not** train on private keys—use evidence_refs only.
- Guardrails: **must_use_hsm:true** forbids software key gen; deny issuance if SAN/CN violates naming policy or ownership proof; rotation only in rotation_window unless emergency; writes scoped to CA/KMS/OCSP/CDP endpoints and rotation queues.

Decisions it makes (deterministic + model-assisted):

- **CSR validation & approval:** profile match, key params and PoP, CN/SAN policy, CABF/NIST conformance; approve/deny with rationale.
- **Issuance path:** CA profile selection, chain (EE → Int → Root), signed cert and bundle delivery target(s).
- **Rotation:** schedule based on **days_remaining**, policy windows, deployment blast radius; opportunistic early rotation for weak algs.
- **Revocation:** determine reason code (key_compromise, affiliation_changed, superseded, cessation_of_operation); choose CRL vs OCSP (or both), compute cache/TTL.
- **Trust distribution:** when anchors/intermediates change, publish **TrustStoreUpdate** and gate promotion to production.
- **Escrow/backup (if allowed):** sealed backup references (never raw key) with HSM attestations; block for keys tagged “no_escrow”.

Routing / where outputs go:

- **Issued Certificates** → CSR channel (CA API response) and deployment refs (k8s secret/ingress, ELB, API gateway, device MDM).
- **Revocation Artifacts** → CRL distribution points (CDP) and/or OCSP responder (or stapling caches).

- **Rotation Jobs** → KMS/secret stores/config repos; notify deployment owners.
- **TrustStoreUpdate** → OS/device/agent trust bundles, gateway roots/intermediates.

Automation scope vs. manual/HITL:

- **Fully automated:** standard server cert issuance/renewals, routine rotations, OCSP/CRL publication, KMS minor-version promotions.
- **HITL required:** root/ICA operations; mass revocation events; algorithm downgrade; cross-org anchor changes; escrow enablement.
- **Manual outside agent:** legal/compliance acceptance of external trust anchors; PKI policy definition; disaster-recovery rituals (key ceremony).

Security Domain: Identity, Credential, and Access Management (ICAM)

Inputs (native protocols consumed) [Informative]

1. **CSR Requests — PKCS#10 (PEM) via REST/ACME** — enrollment of EE certificates.
2. **Expiry Events — Inventory/Telemetry** — impending notAfter, affected deployments.
3. **KMS State — Cloud/on-prem KMS/HSM** — key metadata, versions, attestation.

Example: Consumed Protocol — CSR (PKCS#10 / ACME enrollment) [Informative]

Native payload (CSR, PEM)

-----BEGIN CERTIFICATE REQUEST-----

MIIC3TCCAcUCAQAwwYExCzAJBgNVBAYTAIVTMRAwDgYDVQQIDAdOZXcgWW9ya
zEQ

MA4GA1UEBwwHTmV3IFlvcmsxFTATBgNVBAoMDEFjbmUgcGF5bWVudHMxZjAUBg
NV

BA5MDVBheW1lbnRzIEJ1aWxkMR8wHQYDVQQDDDBHcGkucGF5bWVudHMxZjAUBg
XBs

ZS5jb20wWTATBgqhkhjOPQIBBggqhkhjOPQMBBwNCAAS3m2...snip...

-----END CERTIFICATE REQUEST-----

MCP-wrapped payload

{

```

"mcp_context": {
  "mcp_version": "0.9",
  "mission_id": "uuid-c7-csr-1111-2222-3333-4444",
  "thread_id": "uuid-enroll-api.payments.example.com",
  "task_id": "uuid-aa11-bb22-cc33-dd44",
  "role": "CryptoKeyManagerAgent",
  "intent": "implement",
  "constraints": ["rotation_window:offhours", "must_use_hsm:true"],
  "policy_refs": ["SC-12", "SC-13", "IA-5", "NIST-800-57"],
  "decision_basis": {
    "evidence_refs": ["uri://csr/inbox/api.payments.example.com/2025-08-15T14:30:00Z"],
    "confidence": 0.99,
    "explanation_ref": "uri://kb/pki/enrollment#pkcs10-profile-server-tls"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/icam/crypto-key-manager-agent",
    "signing_kid": "kid-pki-c7-01",
    "hsm_attestation_ref": "uri://attest/hsm/yubiHSM2@sha256:a1b2c3",
    "attestation_ref": "uri://slsa/attestations/ckm@sha256:enroll01"
  },
  "classification": "C3",
  "legal_hold": false
},
"native_payload": "-----BEGIN CERTIFICATE REQUEST-----\nMIIC3T...snip...\n-----END CERTIFICATE REQUEST-----"
}

```

If ACME (RFC 8555) is used, the native request includes newOrder with identifiers and JWS proof; use the same MCP wrapper with evidence_refs pointing to the ACME order URL.

Example: Consumed Protocol — Expiry Events [Informative]

Native payload

```
{
  "event_type": "cert_expiry_approaching",
  "cert_fingerprint_sha256": "5D:92:....:AF",
  "subject": "CN=api.payments.example.com",
  "issuer": "CN=Corp-Intermediate-01",
  "not_before": "2024-08-20T00:00:00Z",
  "not_after": "2025-08-20T00:00:00Z",
  "days_remaining": 5,
  "path_end_entity": true,
  "deployment_refs": ["k8s://payments/api-gateway/ingress-tls", "elb://prod-payments-elb-1"]
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-c7-exp-5555-6666-7777-8888",
    "thread_id": "uuid-expiry-api.payments.example.com",
    "task_id": "uuid-9911-8822-7733-6644",
    "role": "CryptoKeyManagerAgent",
    "intent": "maintain",
    "constraints": ["rotation_window:offhours"],
    "policy_refs": ["SC-12", "SC-13", "NIST-800-57"],
    "decision_basis": {
```

```

    "evidence_refs": ["uri://cert-inventory/fingerprint/sha256/5D:92:....:AF"],
    "confidence": 0.98,
    "explanation_ref": "uri://kb/pki/rotation-policy#t-minus-7-days"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/icam/crypto-key-manager-agent",
    "signing_kid": "kid-exp-c7-02",
    "attestation_ref": "uri://slsa/attestations/ckm@sha256:expiry02"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { "...": "as above" }
}

```

Example: Consumed Protocol — KMS State [Informative]

Native payload

```

{
  "key_id": "kms-keys/prod-tls-key",
  "algorithm": "EC_P256",
  "purpose": "ASYMMETRIC_SIGN",
  "state": "ENABLED",
  "primary_version": "5",
  "versions": [
    {"version": "3", "state": "DISABLED", "create_time": "2024-05-02T11:20:00Z"},
    {"version": "4", "state": "ENABLED", "create_time": "2025-03-15T08:10:00Z"},
    {"version": "5", "state": "ENABLED", "create_time": "2025-07-30T09:45:00Z"},
    {"primary": true}
  ],
}

```

```

"rotation_period_days": 180,
"next_rotation_on_or_after": "2026-01-26T00:00:00Z",
"hsm_backed": true,
"attestation": "attest://kms/hsm/quote/ab12cd..."
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-c7-kms-aaaa-bbbb-cccc-dddd",
    "thread_id": "uuid-kms-state-prod-tls-key",
    "task_id": "uuid-1122-3344-5566-7788",
    "role": "CryptoKeyManagerAgent",
    "intent": "maintain",
    "constraints": ["rotation_window:offhours", "must_use_hsm:true"],
    "policy_refs": ["SC-12", "SC-13", "NIST-800-57", "FIPS-140-3"],
    "decision_basis": {
      "evidence_refs": ["uri://kms/keys/prod-tls-key/meta"],
      "confidence": 0.97,
      "explanation_ref": "uri://kb/kms/rotation-and-versioning#180d-policy"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/icam/crypto-key-manager-agent",
      "signing_kid": "kid-kms-c7-03",
      "hsm_attestation_ref": "attest://kms/hsm/quote/ab12cd...",
      "attestation_ref": "uri://slsa/attestations/ckm@sha256:kms03"
    },
  },

```

```

    "classification": "C3",
    "legal_hold": false
  },
  "native_payload": { "...": "as above" }
}

```

Outputs (native) [Informative]

- **Issued Certificates** (X.509 DER/PEM) + chain/bundle.
- **Revocation Artifacts** (CRL updates; OCSP responses / stapling config).
- **Rotation Jobs** (KMS rotate version, reissue, distribute trust updates).

MCP context (required) [Informative]

mission_id; role="CryptoKeyManagerAgent"; intent in {"implement","maintain"};
 constraints (e.g., "rotation_window:offhours", "must_use_hsm:true");
 provenance.attestation (SPIFFE/SLSA + KID; include HSM/KMS attestation for key ops)

MCP context (optional) [Informative]

policy_refs (SC-12, SC-13, IA-5, 800-57, alg profiles); classification (C2 for public cert data; **C3** for any private-key-adjacent op); decision_basis; legal_hold

Enforcement note [Informative]

PEPs and consumers **MUST** validate certificate chain, EKU, name constraints, revocation status (OCSP/CRL), and provenance.attestation on config changes. KMS rotations require verified HSM/KMS quotes when **must_use_hsm:true**. Rotation actions outside rotation_window require emergency/HITL tokens.

NIST SP 800-160v2 linkage [Informative]

Implement & Maintain — resilient cryptographic resource management and trust anchors.

Automation feasibility [Informative]

High (policy-driven issuance/rotation/revocation; HITL for anchors, mass revocations, and policy exceptions).

Output Contracts (merged) [Informative]

OC-1: IssuedCertificatePublish [Informative]

- **Producer(s):** C7
- **Topic/Path:** CA API response channel and deployment refs (e.g., k8s://.../secret, elb://..., git://cert-deploy/<svc>).
- **Schema/Format:** JSON {request_id, cert_pem, chain_pem[], fingerprint_sha256, not_before, not_after, profile_id, key_ref, san[], deployment_refs[], evidence_refs[]}
- **Classification:** C2 (public cert data)
- **Delivery:** at-least-once
- **Ordering:** per request_id
- **Idempotency-Key:** sha256(request_id, fingerprint_sha256)
- **Ack/Nack:** 2xx/ACK from CA or deployment hook; NACK on policy/verify failure
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x
- **Side-Effects:** inventory index update; trigger trust distribution to targets
- **HITL Token:** none
- **Observability:** trace_id, mission_id, policy_refs, provenance.attestation
- **Retention/TTL:** 7 years (audit)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=IssuedCertificatePublish@1.0 | json_schema_uri=uri://schema/issued-certificate-publish-1.0.json | sha256= | producers=C7 | consumers=Deploy-Targets, Inventory-01 | accepts=1.0–1.x

OC-2: RevocationArtifactPublish (CRL/OCSP) [Informative]

- **Producer(s):** C7
- **Topic/Path:** pki.cdp.update.v1 (CRL) and/or pki.ocsp.update.v1 (OCSP)
- **Schema/Format:** JSON {artifact_type in ["CRL","OCSP"], ca_id, crl_der? , ocsp_response_der?, affected_serials[], reason_code?, next_update, cdn_urls[], evidence_refs[]}
- **Classification:** C1
- **Delivery:** at-least-once

- **Ordering:** per ca_id
- **Idempotency-Key:** sha256(ca_id, next_update)
- **Ack/Nack:** CDN/Responder ACK; retry/backoff
- **Side-Effects:** purge caches; notify stapling agents
- **HITL Token:** required when mass revocation count exceeds threshold
- **Retention/TTL:** per PKI policy (≥ 1 year)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: Whenever a revocation occurs or scheduled CRL/OCSP update is due
 schema_id=RevocationArtifactPublish@1.0 | json_schema_uri=uri://schema/revocation-artifact-publish-1.0.json

OC-3: RotationJob [Informative]

- **Producer(s):** C7
- **Topic/Path:** pki.rotation.jobs.v1
- **Schema/Format:** JSON {job_id, key_id, action in ["kms_rotate", "reissue_cert", "redistribute"], schedule_window, deployment_refs[], justification, risk_level, evidence_refs[]}
- **Classification:** C2 (C3 if key_id details sensitive)
- **Delivery:** at-least-once
- **Ordering:** per key_id
- **Idempotency-Key:** sha256(job_id)
- **Ack/Nack:** worker ACK; retry/backoff
- **Side-Effects:** staged secrets/configs; canary deploy; post-rotate validation
- **HITL Token:** required if action affects trust anchors or outside rotation_window
- **Retention/TTL:** 3 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When rotation is scheduled or triggered
 schema_id=RotationJob@1.0 | json_schema_uri=uri://schema/rotation-job-1.0.json

OC-4: TrustStoreUpdate [Informative]

- **Producer(s):** C7
- **Topic/Path:** pki.truststore.update.v1 (device/agent/OS bundles; gateway roots/intermediates)
- **Schema/Format:** JSON {bundle_id, anchors[], intermediates[], removal_list[], target_fleets[], rollout_policy, evidence_refs[]}
- **Classification:** C1
- **Delivery:** at-least-once
- **Ordering:** per bundle_id
- **Idempotency-Key:** sha256(bundle_id, version)
- **Ack/Nack:** fleet/MDM ACK; retry/backoff
- **HITL Token:** required for anchor removal
- **Retention/TTL:** 7 years

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When enterprise manages custom trust stores or anchors change
schema_id=TrustStoreUpdate@1.0 | json_schema_uri=uri://schema/truststore-update-1.0.json

OC-5: KeyCompromiseEvent [Informative]

- **Producer(s):** C7
- **Topic/Path:** pki.key.compromise.v1
- **Schema/Format:** JSON {event_id, key_id or cert_serial, compromise_indicator, detection_source, severity, immediate_actions[], evidence_refs[]}
- **Classification:** C3
- **Delivery:** at-least-once
- **Ordering:** per key_id
- **Idempotency-Key:** sha256(event_id)
- **Ack/Nack:** SIEM/IR ACK; retry/backoff; open incident
- **HITL Token:** none (event), but revocations spawned will require policy gates

- **Retention/TTL:** 7 years

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When compromise is suspected or confirmed

schema_id=KeyCompromiseEvent@1.0 | json_schema_uri=uri://schema/key-compromise-event-1.0.json

State machine (concise) [Informative]

states = { idle, validating_csr, issuing, distributing, monitoring, rotating, publishing_crl, publishing_ocsp, updating_truststore, revoking, contested, failed, closed }

transition(idle -> validating_csr) on CSR/ACME order intake

transition(validating_csr -> issuing) when policy & PoP pass

transition(issuing -> distributing) when cert signed and verified

transition(monitoring -> rotating) when days_remaining <= threshold or policy trigger

transition(rotating -> distributing) on successful reissue/rollout

transition(monitoring -> revoking) on compromise/affiliation change

transition(revoking -> publishing_crl) when CRL path chosen

transition(revoking -> publishing_ocsp) when OCSP path chosen

transition(* -> updating_truststore) on anchor/intermediate change

transition(* -> contested) when policy exception or appeal lodged

transition(* -> failed) on signature/schema/NACK errors

timeout(distributing, 60s) -> failed; retry<=5

idempotency_key = sha256(request_id, fingerprint_sha256) for

IssuedCertificatePublish; sha256(ca_id, next_update) for RevocationArtifactPublish;

sha256(job_id) for RotationJob

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 IssuedCertificatePublish	Required	Always	Delivers valid certs to services
OC-2 RevocationArtifactPublish	Conditionally Required	Any revocation or scheduled CRL/OCSP update	Enforces revocation

Output Contract	Requirement Level	Trigger Condition	Business Impact
			status enterprise-wide
OC-3 RotationJob	Conditionally Required	Rotation scheduled/triggered	Prevents expiry/weak-alg exposure
OC-4 TrustStoreUpdate	Conditionally Required	Anchors/intermediates change; enterprise trust bundles	Consistent trust across fleets
OC-5 KeyCompromiseEvent	Conditionally Required	Suspected/confirmed compromise	Rapid IR, revocation cascade

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** SC-12, SC-13, IA-5 (+ 800-57 profiles, 800-52r2 TLS baselines).
- **HITL required:** root/ICA changes; anchor removals; mass revocations; algorithm downgrade; operations outside rotation_window without emergency token.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; mass_revocation_count >= threshold; anchor_delta_detected = true.

SLOs and KPIs [Informative]

- **IssuanceAck_p95** <= 60 s (CSR → cert published)
- **RotationCutover_p95** <= 15 min (including canary validation)
- **RevocationPropagation_p95** <= 10 min (OCSP/CRL cache purge)
- **ExpiredCertIncidents_30d** == 0

- **WeakAlgExposure_rolling == 0**

Outputs index [Informative]

[OC-1 IssuedCertificatePublish], [OC-2 RevocationArtifactPublish], [OC-3 RotationJob], [OC-4 TrustStoreUpdate], [OC-5 KeyCompromiseEvent]

Technical Implementation Details (C7) [Informative]

Model and training profile [Informative]

model_id=ckm-text-model; temperature=0.1; max_tokens_out=650
 prompt_pack_id=pki-kms-v1 (CSR vetting, profile selection, rotation/revocation playbooks)
 RAG: sources={CA policy repo, cert inventory index, deployment registry, HSM/KMS attestation docs}; max_docs=8; min_similarity=0.78; citations required
 fine_tuning/adapters: none initially; eval on CSR vetting precision and false-positive revocation rate
 guardrails: enforce **must_use_hsm:true** for key ops; deny writes beyond CA/KMS/OCSP/CDP and rotation queues; never log private key material

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal (CSRs, issues, rotations, revocations), ttl=365d
 semantic_memory: namespaces=["profiles","inventory","deployments","anchors"];
 embeddings=text-embedding-sec-v1; k=8
 durable_state_store: event-sourced; snapshot on each cert issue/rotation
 consistency: at-least-once (events); exactly-once per request_id/job_id for issuance and rotation
 idempotency: per Output Contracts

Decision and routing logic [Informative]

Define features:

- $f_time = 1 - \text{clamp}(\text{days_remaining} / \text{rotation_period_days}, 0, 1)$
- $f_alg = 1$ if algorithm meets policy else 0 (or a graded 0..1 if transitional)
- f_blast in $[0,1]$ (deployment blast radius)
- f_health in $[0,1]$ (KMS/HSM health & attestation)
- $f_policy_nonconform$ in $[0,1]$

rotation_priority_score = 0.4f_time + 0.25(1 - f_alg) + 0.2f_blast + 0.1(1 - f_health) + 0.05*f_policy_nonconform

Thresholds:

- if rotation_priority_score >= 0.7 → emit **RotationJob** for next rotation_window.
- if compromise_indicator = true → emit **KeyCompromiseEvent** and **RevocationArtifactPublish** (reason=key_compromise) immediately.

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[CSR goldens, malformed CSRs, weak-alg cases, OCSP/CRL edge cases]

thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below

red_team_cycle: monthly PKI/KMS attack simulations (MDM/MD5 confusion, key exfil attempts, OCSP stapling abuse)

rollback_policy: revert last good profile/prompt if ExpiredCertIncidents_7d > 0 or RevocationPropagation_p95 breached twice

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: req/profile, CN/SAN, key params, evidence_refs, attestation refs, rollout status, hashes

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL; store cert/CRL/OCSP digests and deployment refs

Incident Response Integration [Informative]

emit KeyCompromiseEvent to SIEM; auto-create revocation playbook in SOAR; coordinate CRL/OCSP updates and TrustStoreUpdate if anchors implicated

Change Impact Assessment [Informative]

simulate alg/profile change against inventory; compute services impacted and cutover time; block if projected downtime > SLO

Stakeholder Feedback Loop [Informative]

collect deploy-owner feedback on rotation windows and failures; update rollout rules post-governance review; never auto-train on sensitive artifacts

Data Sovereignty and Legal Hold [Informative]

regionalize issuance and OCSP/CRL endpoints; set legal_hold=true to freeze key state and extend retention; forbid cross-region anchor edits without HITL

Interfaces (links only) [Informative]

Consumes: CSR/ACME; Expiry Events; KMS/HSM state
Produces: OC-1, OC-2, OC-3, OC-4, OC-5 (as enabled)

Safety and abuse prevention [Informative]

kill_switch on invalid attestation or signature anomalies; cap rotation concurrency; deny anchor changes without HITL; rate-limit issuance per domain

Testing and validation [Informative]

contract tests from Schema Capsules; offline replay of expiries/rotations; chaos tests (OCSP/CDP outages); drift checks and rollback

Deployment and lifecycle [Informative]

HPA on issuance/rotation queue depth; canary rotations; SBOM + SLSA attestations; sign all outputs; scheduled key overlap windows

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-57 Parts 1-3; NIST SP 800-52r2; NIST SP 800-131A; NIST SP 800-63; FIPS 140-3; RFC 5280 (X.509); RFC 6960 (OCSP); RFC 8555 (ACME); PKCS#11; CAB/F Baseline Requirements.

MCP-Native Protocol Specification (C7) [Normative]

- **Native Protocol(s) Consumed:** PKCS#10 CSR via REST/ACME; Inventory/Telemetry expiry events; KMS/HSM state (AWS KMS/Azure KV/GCP KMS or PKCS#11 adapters).
- **Native Protocol(s) Produced:** IssuedCertificatePublish; RevocationArtifactPublish (CRL/OCSP); RotationJob; TrustStoreUpdate; KeyCompromiseEvent.
- **MCP Context Fields:**
 - **Required:** mission_id; role="CryptoKeyManagerAgent"; intent in {"implement","maintain"}; constraints (rotation_window, must_use_hsm); provenance.attestation (include HSM/KMS attestations for key ops).
 - **Optional:** policy_refs; classification; decision_basis; legal_hold.
- **Enforcement Note:** Consumers must validate provenance and reject artifacts/configs lacking policy-compliant attestation; KMS actions require verified quotes; rotation outside windows requires emergency tokens.

- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** canonical native + MCP-wrapped CSR/Expiry/KMS examples above.
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.